Parisar

End-to-End QA, Testing and Release Readiness

Testing documentation and results for the Parisar society management web application.

Contents:

1. Release Readiness Report
2. QA Master Testing Plan
3. Screen-by-Screen Test Cases
4. Role and Permission Testing
5. API and Database Testing
6. Security Testing
7. Performance Testing
8. Appendix: Bug Tracker

Parisar: Release Readiness Report

Date: 10 November 2026. **Build:** branch `feat/saas-onboarding` (local, uncommitted). **Environment:** local developer laptop with Next.js in development mode and local Supabase. There is no staging environment.

1. Executive summary

Recommendation: not ready for production release.

The core of the product works where it was tested. The complaint loop works end to end apart from live updates, and the API enforces roles and keeps societies apart: no cross-society leak was found in 38 isolation checks. The public website and Connect With Us flow pass.

Four things block release:

1. **Dev backdoors are still in the build** (SEC-002, Critical). These are the fixed OTP `123456` for 30 numbers, on-screen OTPs, `/dev-login` and a dev PIN fallback. Today they're switched off by environment settings, but they must be removed before any deployment.
2. **Two main pages crash.** `/notices` and `/polls` return HTTP 500 on load (CORE-001 and CORE-002).
3. **The core loop doesn't update live, and notifications aren't delivered.** New complaints and status changes appear only after a page reload (CORE-005 and CORE-006). Push notifications are queued but never sent, because no provider or worker is configured.
4. **A member can file a complaint under any other flat** in the society (API-001, High). Residents can also read every flat's visitor log, including visitor phone numbers (API-002).

Coverage is also incomplete:

- **Browser testing:** about a quarter of the screens got full screen-by-screen tests in this pass. Many of the rest were checked at the API level, and 105 browser cases are written and ready to run.
- **Performance:** not tested at the required scale.
- **Security:** several checks (XSS, SQL injection, CSRF, CORS, rate limits) are written but not yet run.

2. Summary metrics

Metric	Value
Modules implemented	17 (section 5 of the master plan)
Modules in the brief but not implemented	12
Screens (routes and console sections)	61
Features classified	29 by the testers, plus the full list in section 3
Test cases written	396
Passed	268
Failed	20
Blocked	2
Not tested	106 (105 ready-to-run browser cases, plus 1 not verified)
Bugs logged	24
Critical bugs	1
High bugs	7
Medium bugs	5
Low bugs	11

Metric	Value
Features ready for release (tested, no open High or Critical bug)	9

Test cases by area:

Area	Cases	Pass	Fail	Blocked	Not tested
Public website and authentication (browser)	29	27	1	1	0
Core modules (browser)	34	24	8	1	1
Roles, API and database	208	205	3	0	0
Security	20	12	8	0	0
Remaining screens (written, not run)	105	0	0	0	105

The 3 role and API failures are test-script errors, not product defects (see the role document, section 4.2). The real defects found there are API-001 to API-003. The local load baseline is reported separately and isn't counted as pass or fail.

3. Complete feature inventory and classification

Classifications:

- **Fully Working:** tested, with no open High or Critical bug.
- **Partially Working:** works with open defects.
- **Backend Only:** tested at the API level, with no browser run in this pass.
- **Not Tested:** exists, but wasn't tested in this pass.

Module	Feature	Classification	Evidence
Public website	Landing page	Fully Working	ONB-TC
Public website	Connect With Us (validation, several authority numbers, schedule, duplicates)	Fully Working	ONB-TC, API `connect` (32 of 33 pass; the 1 failure is a harness error)
Public website	Request success page and status lookup	Fully Working	ONB-TC
Public website	`/enroll` redirect	Fully Working	ONB-TC
Authentication	OTP login (dev stub)	Fully Working in dev; production SMS **Not Implemented**	ONB-TC, SEC
Authentication	PIN as second step	Partially Working	SEC-003, SEC-004, SEC-005
Authentication	Signed-out protection and open-redirect protection	Fully Working	SEC section 4
Authentication	`/verify` opened directly	Partially Working	ONB-001 (Low)
Platform admin	Request management, register society, society code, feature toggles	Backend Only	API `connect` and `authority`; ADM-TC Not Tested
Platform admin	Feature enablement enforced for users	Partially Working	Sidebar hides switched-off features, but the pages still open by URL (CORE-004)
Society setup	Wings, floors, flats, draft, completion	Backend Only	API `setup` (18 of 18 pass); SET-TC Not Tested

Module	Feature	Classification	Evidence
Excel import	Validate, preview, import	Backend Only	API workflows; IMP-TC Not Tested
Resident verification	Confirm, correct, report; admin review	Not Tested	VER-TC
Onboarding	Owner, tenant, family, household	Backend Only	API `onboard` (7 of 7 pass); ONBD, APR and HH cases Not Tested
Roles	Role-by-RPC authorization (each RPC called as anon, platform admin, chairman, treasurer, committee member, member, guard and a different society's users)	Fully Working	Role document 4.2
Multi-society	Isolation across tables and RPCs	Fully Working	API `iso` (38 of 38 pass)
Dashboard	Home dashboard for an authority with no flat	Not Working	CORE-003 (redirects to onboarding)
Dashboard	Society Dashboard, society profile	Fully Working (loads)	CORE-TC-002 and 003
Complaints	File with photo, board claim, respond, resolve	Fully Working	CORE-TC-017 to 027
Complaints	Live updates to board and reporter	Partially Working	CORE-005, CORE-006
Complaints	Resident notification	Blocked	CORE-TC-034: no push worker or provider
Complaints	Attribution to own flat only	Not Working	API-001 (High)
Complaints	Search, filter, pagination	Not Implemented	features-core
Notices	List page	Not Working	CORE-001 (HTTP 500)
Notices	Create and read (API)	Backend Only	API `notices` (6 of 6 pass)
Polls	List page	Not Working	CORE-002 (HTTP 500)
Polls	Vote, results (API)	Backend Only	API `polls` (10 of 10 pass)
Bookings	Request, approve, overlap refusal	Backend Only	API `bookings` (12 of 13 pass; overlap correctly refused)
Visitors	Guard logs visit, resident decides	Partially Working	API `visitors` (8 of 10 pass); API-002 (all residents read all visits)
SOS	Raise and resolve	Partially Working	API `sos` (9 of 9 pass); API-003 (guard cannot resolve guard SOS)
Facilities, community, flat actions	Pages load	Not Tested beyond route smoke	CORE-TC-010 to 016
Staff	Staff management and directory	Not Tested	STF-TC
Directory, review queue, code rotation, role transfer, settings, profile		Not Tested in browser	Section K cases
Vehicles, parking, maintenance billing, payments, accounting, events, vendors, documents, reports, deliveries, expected visitors, staff attendance		**Not Implemented**	No routes; listed in `HIDDEN_NAV_ITEMS`

Module	Feature	Classification	Evidence
Staff logins (plumber, electrician, cleaner, other)		**Not Implemented** by design (records only)	Role document section 2
Performance at 100 to 5,000 users		Not Tested	Performance document

4. Screen inventory and user role matrix

See the master plan, section 6, for all 61 screens. The role-to-screen visibility matrix and the role-by-API matrix are in `PARISAR_ROLE_PERMISSION_TESTING.md`, section 4.

5. Test reports by type

Report	Where	Headline
Screen-by-screen	`PARISAR_SCREEN_BY_SCREEN_TEST_CASES.md`	63 executed browser cases, 105 ready to run
Field validation	`PARISAR_FIELD_AND_BUTTON_VALIDATION.xlsx`, Fields sheet	Executed rows for the public, auth and complaint forms; designed rows for the others
Button testing	Same workbook, Buttons sheet	
Navigation	Screen document, common checks C1 to C7	Signed-out redirects pass; feature-gated pages reachable by URL (CORE-004); no unsaved-changes warning on complaints (CORE-009)
API	`PARISAR_API_DATABASE_TESTING.md`	208 executed cases across 13 areas
Database	Same document	Rows verified after each workflow; no duplicates on double submit (CORE-TC-023)
Security	`PARISAR_SECURITY_TESTING.md`	1 Critical, 1 High, 2 Medium, 5 Low; XSS, SQL injection, CSRF and CORS not yet run
Performance	`PARISAR_PERFORMANCE_TESTING.md`	Local API reached 500 to 1,000 requests per second with p99 230 to 520 ms at 10 to 50 connections. Laptop-bound; **not a capacity result**

6. Critical and high issues

ID	Severity	Issue	Required fix
SEC-002	Critical	Dev backdoors in the build: `test_otp`, on-screen OTP hook, DevOtpHint, `/dev-login`, `/dev-preview`, dev PIN pepper fallback	Remove them, and check the CI guard (`scripts/check-no-dev-otp.mjs`) blocks a deploy that still has them
SEC-001	High	Dev server and database listen on all network interfaces with dev auto-login on	Bind to localhost in development; never run dev routes on a shared network
API-001	High	A member can file a complaint attributed to any flat in their society	Check in `file_complaint` that the flat is the caller's own unless the caller is a manager
CORE-001	High	`/notices` returns HTTP 500	Fix the server render error; add a render test
CORE-002	High	`/polls` returns HTTP 500	Same
CORE-003	High	Authority with no flat cannot reach `/dashboard`	Let authorities without a flat into the dashboard, or offer an explicit choice

ID	Severity	Issue	Required fix
CORE-005	High	New complaints don't appear live for the board	Fix the realtime subscription filter or channel
CORE-006	High	The reporter's status badge doesn't update live	Update the status from the realtime event, not only the trail

Medium issues to fix before release:

- **API-002:** visitor log readable by every resident.
- **CORE-004:** switched-off features reachable by URL; gate them server-side.
- **CORE-007:** orphaned and unvalidated uploads.
- **SEC-003:** PIN not enforced server-side.
- **SEC-004:** guessable legacy PIN credential.

7. Partially working features

- Complaint live updates
- Visitors (cross-flat read)
- SOS (guard resolve)
- PIN second step
- Feature enablement (UI only)
- `/verify` direct open

8. Features not implemented

- Vehicles, parking, maintenance billing and dues, payments, accounting, events, vendors, document library, reports, deliveries, expected visitors and staff attendance
- Complaint search, filter and pagination
- SMS provider and email
- Logins for plumber, electrician, cleaner and other staff (by design)
- Onboarding fields from the brief that aren't in the forms (middle name, profile photo, date of birth, gender, police verification as a separate field). Confirm with ONBD-TC.

9. Features ready for release

Ready means tested, with no open High or Critical issue in the feature:

1. Landing page
2. Connect With Us
3. Request status page
4. `/enroll` redirect
5. Signed-out route protection and open-redirect protection
6. Role-based API authorization
7. Multi-society isolation
8. Society Dashboard and society profile pages (load)
9. Filing a complaint with a photo, and the board's claim, response and resolve actions

Even these can only ship once SEC-002 is fixed, because it affects the whole build.

10. Features not ready for release

Everything else in section 3:

- **Not Working or Partially Working:** these items need the fixes in section 6.
- **Backend Only or Not Tested:** run the 105 ready cases in Part 3 of the screen document first.

11. Required fixes before release, in order

1. Remove the dev backdoors (SEC-002) and lock development binding (SEC-001).
2. Fix `/notices` and `/polls` (CORE-001, CORE-002) and the authority dashboard redirect (CORE-003).
3. Restrict complaint flat attribution (API-001) and the visitor log (API-002).
4. Fix realtime for complaints (CORE-005, CORE-006).
5. Choose and integrate the SMS provider, and run the push worker, so OTPs and notifications work outside development.
6. Gate switched-off features server-side (CORE-004).
7. Run the 105 ready browser cases and the security checks still to run (security document, section 7).
8. Set up staging and run the performance plan at 100, 500, 1,000, 2,000 and 5,000 users.
9. Re-run the full regression suite (master plan, section 23).

12. Final release recommendation

Do not release yet. Release after items 1 to 7 in section 11 are done and re-tested, and after a staging performance run shows the target load is met. A limited pilot with one friendly society is reasonable once items 1 to 5 are done, provided its expected load is small and someone watches the system during the pilot.

13. Testing limitations

- **Interruptions:** testing ran in several interrupted sessions on one laptop. Some planned browser coverage didn't run, and it is marked Not Tested rather than assumed.
- **Production configuration:** the web app ran in development mode, so production settings (HttpOnly cookies, headers, source maps) need a production-build re-check.
- **Notifications:** push and SMS couldn't be tested end to end locally.
- **Earlier evidence:** 143 screenshots of the onboarding screens from 7 November (`docs/onboarding/screenshots/`) predate this pass and aren't counted as passes here.

Parisar: QA Master Testing Plan

Date: 10 November 2026. **Build under test:** branch `feat/saas-onboarding` (local, uncommitted), web app and Supabase backend. **Environment:** local developer laptop. There is no staging environment yet.

This plan is the entry point for testing. It explains what Parisar is, how it's built, who uses it, what to test and in which order. It also explains where each set of test cases lives and how to record results. Everything here is based on inspecting the actual code and running the app, not on the product brief.

1. Project overview

Parisar is a society-management platform for Indian housing societies. It has a public website, a resident and committee web app, a platform-admin console, a security-guard console and an Expo mobile app. The mobile app is outside this QA pass.

The core loop that must always work: **a resident files a complaint, a board member responds, the status updates, and the resident is notified.** Other modules cover:

- Notices, polls, amenity bookings and the facility calendar
- Community posts with moderation
- Flat actions (warnings, fines and notices; fines are recorded only, with no payments)
- Visitors at the gate, staff directory, SOS and the member directory
- The onboarding journey, from a society's first contact through setup, Excel import and resident verification

2. Existing application architecture

Layer	Implementation
Web app	Next.js 15 App Router, JavaScript only, in `apps/web`. Server components check the session with `getUser()`. Middleware redirects signed-out users to `/login`
API	No separate API server. The web app calls Supabase directly: PostgREST tables (`/rest/v1/<table>`) and Postgres functions (`/rest/v1/rpc/<name>`), mostly `SECURITY DEFINER` RPCs with their own auth, role and society checks
Authorization	Row-level security on every public table, scoped by `current_society_id()` from the JWT. The JWT hook `inject_society_claims` adds the society and role
Auth	Phone OTP through Supabase Auth, using a dev stub with fixed code `123456` for 30 test numbers. Returning users can use a PIN via the `pin-login` edge function
Storage	Supabase Storage buckets for complaint photos and other attachments, plus the private `parisar-proofs` bucket for owner, tenant and staff documents
Background work	`push_outbox` plus edge functions `notification-fanout`, `push-fanout`, `booking-ack-fanout` and `flat-action-fanout`. **Not running locally**, so push notifications are not delivered in this environment
Shared packages	`packages/api-client` (RPC wrappers), `packages/i18n` (English, Hindi, Marathi), `packages/shared-types`, `packages/ui-tokens`
Database	79 migrations in `supabase/migrations`; local database at version `20261106000092`

3. Technology stack

- **Web:** Next.js 15.2, React 19.2, Tailwind 4, shadcn/base-ui, i18next.
- **Backend:** Supabase (Postgres 15, PostgREST, GoTrue, Storage, Realtime, Edge Functions).
- **Tests:** Vitest for the web (84 test files across web and packages) and `tests/isolation` for row-level security.
- **Do not run `tests/isolation` against a database with real data:** its old helper deletes every society.
- **QA tooling used in this pass:**
- Playwright for browser tests.

- Node scripts in `docs/qa/scripts/api` for API tests.
- autocannon for the local load baseline.
- k6 scripts in `docs/qa/scripts/perf` for staging.

4. User roles

Roles are separate mechanisms, not one field:

- **Platform role:** admin, sales or staff.
- **Membership role:** member, board_member, co_secretary or secretary.
- **Society title:** chairman, secretary, treasurer or committee member. It maps onto a membership role.
- **Resident type:** owner, tenant or family member.
- **Authorities:** a phone list for each society.
- **Gate guards.**
- **Staff records:** these have no login.

The full mapping of the brief's 15 roles, with what each can log into, is in `PARISAR_ROLE_PERMISSION_TESTING.md`, sections 1 and 2. Plumber, electrician, cleaner and other staff are directory records only and cannot sign in.

5. Module inventory

Module	Routes	Status in this build
Public website	`/`, `/connect`, `/connect/success`, `/enroll`	Implemented
Authentication	`/login`, `/verify`, PIN login	Implemented (dev OTP)
Platform admin console	`/c/k7m2x9` (admin), `/c/p4v8qd` (sales), `/c/t6r3wz` (staff)	Implemented
Society setup	`/setup`, `/society`, `/society-dashboard`, `/dashboard/code-rotation`	Implemented
Resident import and verification	`/import`, `/verification`, `/verification/admin`	Implemented
Resident onboarding	`/onboarding`, `/onboarding/status`, `/join/*`, `/household`, `/approvals`, `/invite/[token]`, `/residents/*`	Implemented
Dashboards	`/dashboard` (admin and resident variants), guard console `/c/g8s4muv`	Implemented
Complaints	`/complaints`, `/complaints/new`, `/complaints/[id]`, `/my-complaints`	Implemented
Notices, polls	`/notices`, `/notices/new`, `/notices/[id]`, `/polls`	Implemented (both list pages return HTTP 500: CORE-001 and CORE-002)
Bookings, facility calendar	`/bookings`, `/bookings/new`, `/facilities`	Implemented, feature-gated
Community	`/community`, `/community/new`, `/community/[id]`, `/community/moderation`	Implemented, feature-gated
Flat actions	`/flat-actions`, `/flat-actions/new`, `/flat-actions/[id]`	Implemented, feature-gated
Visitors, guard, SOS	`/visitors`, `/c/g8s4muv`, header SOS button	Implemented
Staff	`/staff`, `/staff/manage`, `/staff/manage/new`, `/staff/manage/[id]`	Implemented (records only, no staff login)

Module	Routes	Status in this build
Directory, review queue, role transfer	`/dashboard/directory`, `/dashboard/review-queue`, `/dashboard/role-transfer`	Implemented
Settings and profile	`/settings/notifications`, `/settings/grievance-officer`, `/profile`, `/about`	Implemented
Vehicles, parking, maintenance billing, payments, accounting, events, vendors, documents, reports, deliveries, expected visitors, staff attendance	none	**Not Implemented**: listed in `HIDDEN_NAV_ITEMS` in `apps/web/lib/nav/sidebarNav.js`

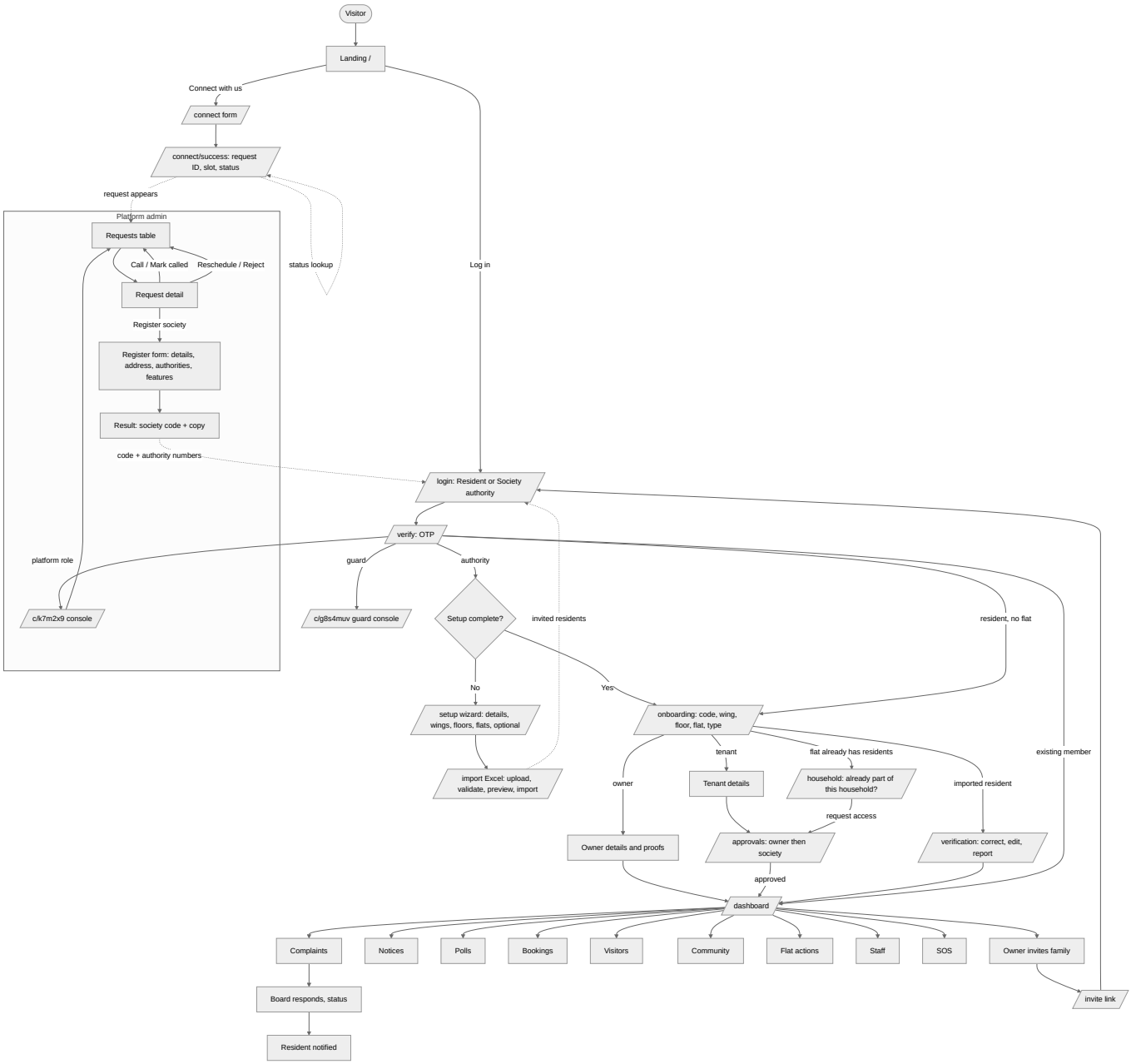
6. Complete screen inventory

The **Testing scope** column says whether a screen got its own browser test cases in this pass or only a route load check.

#	Screen	Route	Testing scope
1	Landing page	`/`	Browser-executed (ONB-TC)
2	Connect With Us	`/connect`	Browser-executed
3	Request success and status	`/connect/success`	Browser-executed
4	Enroll redirect	`/enroll`	Browser-executed
5	Login	`/login`	Browser-executed
6	Verify OTP and PIN	`/verify`	Browser-executed
7	Public invite	`/invite/[token]`	Browser-executed
8-17	Admin console sections (overview, requests, request detail, reschedule, reject, register, result, societies, catalogue, people)	`/c/k7m2x9`	Cases ready (ADM-TC), Not Tested
18	Setup wizard (5 steps)	`/setup`	Cases ready (SET-TC), Not Tested
19	Excel import	`/import`	Cases ready (IMP-TC), Not Tested in browser; API tested
20-21	Verification (resident, admin)	`/verification`, `/verification/admin`	Cases ready (VER-TC)
22-23	Onboarding wizard and status	`/onboarding`, `/onboarding/status`	Cases ready (ONBD-TC)
24	Approvals	`/approvals`	Cases ready (APR-TC)
25-26	Household, invite acceptance	`/household`, `/join/invite/[token]`	Cases ready (HH-TC)
27	Residents lists	`/residents/[type]`	Cases ready (RES-TC)
28-31	Staff manage, new, detail, directory	`/staff/manage*`, `/staff`	Cases ready (STF-TC)
32	Home dashboard	`/dashboard`	Route smoke: **Fail** for an authority with no flat (CORE-003)
33-35	Society dashboard, society profile, code rotation		Route smoke Pass
36-39	Complaints (list, new, detail, my complaints)		Browser-executed end to end (CORE-TC-004 to 034)
40-42	Notices (list, new, detail)		Route smoke: list **Fail** (HTTP 500)
43	Polls	`/polls`	Route smoke **Fail** (HTTP 500)

#	Screen	Route	Testing scope
44-46	Bookings, new booking, facility calendar		Route smoke Pass
47-50	Community (list, new, detail, moderation)		Route smoke Pass
51-53	Flat actions (list, new, detail)		Route smoke Pass (list)
54-61	Visitors, guard console, directory, review queue, role transfer, notification settings, grievance officer, profile		Cases ready (section K), Not Tested in browser

7. Navigation flow



8. Feature-wise test cases

See `PARISAR_SCREEN_BY_SCREEN_TEST_CASES.md`:

- Part 1: public website and authentication, executed.

- Part 2: core modules, executed.
- Part 3: all remaining screens, ready to run.

Feature classifications are in the release readiness report, section 3.

9. Field-wise validation

`PARISAR_FIELD_AND_BUTTON_VALIDATION.xlsx`, sheet **Fields**. Each row records the field, its type, whether it is mandatory, its rules and DB mapping, and its status. Rows for screens not executed in this pass are marked Not Tested.

10. Button-wise testing

The same workbook, sheet **Buttons**. Each row records the expected action, the API called and the status.

11. Next/Back navigation testing

The common checks C1 to C7 are at the top of Part 3 of the screen document. Run them on every screen: signed-out access, wrong role, refresh, back after save, three widths, offline save and keyboard use. Wizard-specific cases: SET-TC-08 and 09 (setup wizard) and ONBD-TC-08 and 09 (onboarding wizard).

12. CRUD testing

Module	Create	Read	Update	Delete	Where
Complaints	Executed	Executed	Status responses executed	Not supported	CORE-TC-017 to 034
Notices, polls, bookings, visitors, SOS	API executed	API executed	API executed	As supported	`PARISAR_API_DATABASE_TESTING.md`
Setup structure (wings, floors, flats)	API executed	API executed	API executed	Delete RPCs exist	API doc (area `setup`), SET-TC
Staff	Not Tested	Not Tested	Not Tested	Not Tested	STF-TC
Community, flat actions	Not Tested	Route smoke	Not Tested	Not Tested	Section K

13. API testing

`PARISAR_API_DATABASE_TESTING.md` covers the API cases executed against the local API, with scripts in `docs/qa/scripts/api/`. Together with the role document, that is 208 executed cases: 205 passed and 3 failed.

14. Database testing

The same document covers row checks after each workflow, duplicate prevention, relationships and isolation.

15. Role and permission testing

`PARISAR_ROLE_PERMISSION_TESTING.md` contains the role-to-screen visibility matrix and a role-by-RPC matrix executed with a real session for each role.

16. Multi-society testing

There are two societies:

- **Society A:** QA Sunrise Heights.
- **Society B:** QA-T Lotus Society.

38 isolation checks passed: no table or RPC returned the other society's data. See the API document, area `iso`.

17. UI/UX testing

Per-screen UI checks (alignment, fonts, overflow, empty, loading, error and success states) are in Parts 1 and 2 of the screen document. Route smoke checked for horizontal overflow at 375 and 1280 px. Known UI bugs: CORE-008 to CORE-011 and ONB-001.

18. Responsive testing

Widths 375, 768 and 1280 px. Executed for the public website and the core routes. Common check C5 applies to the rest.

19. Security testing

`PARISAR_SECURITY_TESTING.md`. It includes **one release blocker:** the dev backdoors, SEC-002.

20. Performance testing

`PARISAR_PERFORMANCE_TESTING.md` contains the staging plan and k6 scripts for 100 to 5,000 users, plus a local baseline. **No capacity claim is made.**

21. Integration testing

Integration	Status
Supabase Auth OTP (dev stub)	Executed
SMS provider (MSG91, Twilio or Firebase)	**Not Implemented**: provider not chosen
Push notifications (FCM through the fanout edge functions)	**Blocked locally**: outbox rows are created but no worker processes them (CORE-TC-034)
Realtime (complaint updates)	Executed: **Fail** for live status and new-complaint updates (CORE-005, CORE-006)
Storage uploads	Complaint photos executed; proofs Not Tested
Excel (exceljs)	API validation executed; browser upload Not Tested in this pass
Email	Not Implemented

22. Negative testing

Negative cases are part of each module's test cases:

- Invalid input, duplicates, double submit and wrong role in the screen and API documents.
- Common checks C1 to C7.
- The security checks still to run (XSS, SQL injection, CSRF), listed in the security document, section 7.

23. Regression testing

Run before every release:

1. `apps/web`: `npx vitest run`. The baseline for this branch is 876 passed and 5 failing (pre-existing, `admin-screens-03-10`).
2. `packages/api-client`: `npx vitest run` (345 passed).
3. `node scripts/check-i18n-coverage.mjs`.
4. `next build`.
5. The API scripts in `docs/qa/scripts/api`, against a **fresh** database seeded only with test data.
6. The core loop: CORE-TC-022 to 029.

24. Bug tracking

Bugs are recorded in `PARISAR_BUG_TRACKER.xlsx`, using the Part 13 format with severity, priority and status dropdowns. When reporting a bug, add a row with the next ID for its area (`ONB`, `CORE`, `API`, `ROLE`, `SEC` or `PERF`), steps, expected and actual results, and evidence. Set the status to Retest after a fix and Closed after it passes.

25. Release readiness

See `PARISAR_RELEASE_READINESS_REPORT.md`.

How to run a test session

1. Start the backend: `supabase start`. Never run `supabase db reset` on a database you care about.
2. Back up the database first: `docker exec supabase_db_parisar pg_dump -U postgres -d postgres -Fc > ~/parisar-backups/<date>.dump`.
3. Start the web app: `cd apps/web && npx next dev`.
4. Sign in with the test numbers listed in Part 3 of the screen document, using OTP `123456`.
5. Execute the cases, saving screenshots to `docs/qa/evidence/<area>/`. Update the status in the markdown and the bug tracker.

Parisar: Screen-by-Screen Test Cases

This document holds every screen-level test case for Parisar. It has three parts:

1. **Public website and authentication**, executed in the browser in this pass (`ONB-TC-*`).
2. **Core society modules**, executed in the browser in this pass: route smoke for every core route, plus the complaints module end to end (`CORE-TC-*`).
3. **Screens not executed in this pass**: ready-to-run cases with status Not Tested (`ADM`, `AUTH`, `SET`, `IMP`, `VER`, `ONBD`, `APR`, `HH`, `RES`, `STF` and the core-module rows).

Evidence screenshots are under `docs/qa/evidence/<area>/`. Field and button details for the executed screens are in `PARISAR_FIELD_AND_BUTTON_VALIDATION.xlsx`. Bugs are in `PARISAR_BUG_TRACKER.xlsx`.

Part 1: Onboarding and Public Website: Screen Tests

Area key: `onboarding`. Tester: QA agent (onboarding). Environment: Local dev: Next.js 15 dev server http://localhost:3000, local Supabase, Chrome headless (Playwright), 2026-11-10.

Counts: 29 test cases, 27 Pass, 1 Fail, 1 Blocked, 0 Not Tested. Bugs: 1 (see `docs/qa/data/bugs-onboarding.json`).

Accounts and test data used

- Group 1 (public pages): signed-out browser, no account. Note: in this dev environment `ENABLE_DEV_ROUTES=1`, so a signed-out visit to a protected route is sent to `/dev-login`, which silently signs in as 9000000005 (not a QA-owned number; no data was written). Production behaviour (redirect to `/login?next=`) cannot be observed here.
- Group 2 (Connect): created requests PR-JM3K-TPQA "QA-T Lotus Society" (contact 9000000001, extra authority 9000000002 "QA-T Ravi Second", slot 11 Nov 11:00 IST, alternative 12 Nov 15:00) and PR-P9DP-PUEF "QA-T Reject Society" (contact 9000000024, As soon as possible). Another tester separately created PR-DF64-PC9E also named "QA-T Lotus Society" (contact 9000000027).

1. Screen inventory

#	Module	Screen	Route	Role	Purpose	Entry point	Previous	Next	Tested
1	Public website	Landing page	`/`	Public (signed out)	Introduce Parisar and route visitors to Connect With Us or Log in	Direct URL / home link	None	/connect or /login	Yes
2	Public website	Connect With Us form	`/connect`	Public (signed out)	Society requests a call from Parisar; lists authority numbers and a call slot	Landing CTA, /enroll redirect	/	/connect/success?code=PR-XXXX-XXXX	Yes
3	Public website	Connect request success / status lookup	`/connect/success`	Public (signed out)	Show the request ID after submission; otherwise look up a request by ID + mobile	Redirect after Send request; direct URL	/connect	/ (Back to home) or /connect (Send a new request)	Yes
4	Public website	Enroll (legacy)	`/enroll`	Public	Old enrollment route, now redirects	Direct URL	n/a	/connect	Yes

#	Module	Screen	Route	Role	Purpose	Entry point	Previous	Next	Tested
5	Authentication	Login	`/login`	Resident / Society authority (signed out)	Enter mobile number and request OTP; toggle Resident vs Society authority	Landing "Log in", middleware redirect	/	/verify	Yes
6	Authentication	Verify OTP / PIN	`/verify`	Signed out, OTP pending	Enter 6-digit OTP, then society picker (authority), set/enter PIN	/login Send OTP	/login	/setup, /onboarding, /dashboard or console depending on account	Yes
7	Family invite	Household invitation (public)	`/invite/[token]`	Public / invitee	Landing for a family invite link; asks invitee to sign in	Shared invite link	n/a	/login then /join/invite/[token]	Yes

2. Screen-by-screen tests

Landing page (`/`)

Screen information. Module: Public website. Role: Public (signed out). Purpose: Introduce Parisar and route visitors to Connect With Us or Log in. Entry point: Direct URL / home link. Previous screen: None. Next screen: /connect or /login.

Field testing. No input fields.

Button testing. Header "Log in" and "Connect with us", hero "Connect with us" and "Log in" links present.

Navigation testing. Header links render; page is public so refresh keeps the page.

UI checks. 1280px and 375px render with no horizontal overflow and no console errors.

ONB-TC-001: Landing page renders at 1280px

- Preconditions: None
- Steps: Open http://localhost:3000/ at 1280x900.
- Test data: n/a
- Expected: Hero, benefits, feature overview, CTAs, footer render; no console errors; no horizontal scroll.
- Actual: Rendered with "Bring your whole society together", Connect with us and Log in CTAs; no console errors; no overflow.
- Status: **Pass**
- Evidence: docs/qa/evidence/onboarding/landing-1280.png

ONB-TC-002: Landing page renders at 375px

- Preconditions: None
- Steps: Open / at 375x812.
- Test data: n/a
- Expected: Responsive layout, no horizontal scroll.
- Actual: Responsive, scrollWidth equals viewport.
- Status: **Pass**
- Evidence: docs/qa/evidence/onboarding/landing-375.png

Connect With Us form (`/connect`)

Screen information. Module: Public website. Role: Public (signed out). Purpose: Society requests a call from Parisar; lists authority numbers and a call slot. Entry point: Landing CTA, /enroll redirect. Previous screen: /. Next screen: /connect/success?code=PR-XXXX-XXXX.

Field testing. Society name (2-120), Your name (2-80), Mobile (+91, 10 digits starting 6-9, non-digits stripped), Email (optional), Authority numbers (extra rows, max 5), Call time radio (At a time I choose / As soon as possible), Preferred date + time, Alternative date + time (optional), Message (optional, max 1000).

Button testing. Send request, Add another number, Remove number (per row), Back to home.

Navigation testing. "Back to home" link. /enroll redirects here.

UI checks. 1280px and 375px render with no horizontal overflow. Required asterisks, "Optional" tags and helper text present.

ONB-TC-003: Connect form renders at 1280px and 375px

- Preconditions: None
- Steps: Open /connect at both widths.
- Test data: n/a
- Expected: All sections visible, no overflow.
- Actual: Society, Your details, Authority numbers, When should we call, Anything else, Send request all visible; no overflow at either width.
- Status: **Pass**
- Evidence: docs/qa/evidence/onboarding/connect-1280.png, docs/qa/evidence/onboarding/connect-375.png

ONB-TC-004: Empty submit shows all required-field errors and focuses first invalid field

- Preconditions: None
- Steps: Open /connect, click Send request without typing.
- Test data: n/a
- Expected: Inline errors for society name, name, mobile, date, time; focus on first invalid field.
- Actual: Errors: "Enter your society's name (2 to 120 characters)", "Enter your name (2 to 80 characters)", "Enter a 10-digit mobile number starting with 6, 7, 8 or 9", "Choose a date", "Choose a time". Focus moved to #connect-society.
- Status: **Pass**
- Evidence: docs/qa/evidence/onboarding/connect-empty-errors-1280.png

ONB-TC-005: One-character names and invalid email rejected

- Preconditions: None
- Steps: Society "Q", name "A", email "abc@", submit.
- Test data: Q / A / abc@
- Expected: Length errors and email error.
- Actual: Length errors shown; "Enter a valid email address, or leave it blank."
- Status: **Pass**
- Evidence: n/a (console log)

ONB-TC-006: Mobile validation: short number and number starting with 5

- Preconditions: None
- Steps: Enter 12345, submit; then 5123456789, submit.
- Test data: n/a
- Expected: Mobile error both times.
- Actual: "Enter a 10-digit mobile number starting with 6, 7, 8 or 9." shown both times.
- Status: **Pass**
- Evidence: n/a

ONB-TC-007: Mobile input strips letters and caps at 10 digits

- Preconditions: None
- Steps: Type "98ab76543210123" in mobile.

- Test data: n/a
- Expected: Only digits kept, max 10.
- Actual: Value became 9876543210.
- Status: **Pass**
- Evidence: n/a

ONB-TC-014: Authority numbers: add up to 5 extra rows, then limit message

- Preconditions: None
- Steps: Enter contact mobile, click "Add another number" until it disappears.
- Test data: n/a
- Expected: Max 5 extra rows; button replaced by limit text.
- Actual: 5 rows added; button replaced with "You can add up to 5 more numbers. Add others after your society is set up."
- Status: **Pass**
- Evidence: docs/qa/evidence/onboarding/connect-authority-limit-1280.png

ONB-TC-015: Authority number duplicate of contact and invalid number rejected

- Preconditions: None
- Steps: Contact 9000000001; row 1 = 9000000001, row 2 = 12, other rows blank; submit.
- Test data: n/a
- Expected: Duplicate and invalid errors on the rows.
- Actual: Row 1 "This number is already on the list."; row 2 and blank rows "Enter a 10-digit mobile number...". Blank added rows are errors rather than ignored.
- Status: **Pass**
- Evidence: docs/qa/evidence/onboarding/connect-authority-dup-1280.png

ONB-TC-016: Remove authority rows

- Preconditions: None
- Steps: Click the trash button on each extra row.
- Test data: n/a
- Expected: Rows removed, Add button returns.
- Actual: All rows removed; Add another number shown again.
- Status: **Pass**
- Evidence: n/a

ONB-TC-017: Message over 1000 characters

- Preconditions: None
- Steps: Type 1005 characters in Message, submit.
- Test data: n/a
- Expected: Counter and error.
- Actual: Field accepts 1005 characters (no maxLength) and shows "Keep the message under 1,000 characters." on submit.
- Status: **Pass**
- Evidence: n/a

ONB-TC-018: Date picker disables past dates

- Preconditions: None
- Steps: Open preferred Date picker on 10 Nov 2026.
- Test data: n/a
- Expected: 1-9 Nov disabled, today onward enabled, max today+89.
- Actual: Calendar opened; 9 past days disabled.
- Status: **Pass**

- Evidence: docs/qa/evidence/onboarding/connect-datepicker-open-1280.png

ONB-TC-019: Preferred slot in the past rejected

- Preconditions: None
- Steps: Pick today (10 Nov), time 00:05, submit.
- Test data: n/a
- Expected: Past-slot error.
- Actual: "This time has already passed. Choose a later time."
- Status: **Pass**
- Evidence: n/a

ONB-TC-020: Alternative slot equal to preferred slot rejected

- Preconditions: None
- Steps: Preferred 11 Nov 11:00, alternative 11 Nov 11:00, submit.
- Test data: n/a
- Expected: Error asking for a different time.
- Actual: "Choose a different time from your preferred one."
- Status: **Pass**
- Evidence: n/a

ONB-TC-021: Valid request with extra authority, schedule and alternative slot is saved

- Preconditions: None
- Steps: Fill all fields (see data), submit. Verify with SQL select on society_enrollment_requests.
- Test data: QA-T Lotus Society / QA-T Asha Lotus / 9000000001 / qa-t-lotus@example.com / authority 9000000002 / 11 Nov 11:00 / 12 Nov 15:00 / message with **bold**
- Expected: Row created with request code, both authority numbers, slots in IST, status new/scheduled.
- Actual: Row PR-JM3K-TPQA, status call_scheduled, authority_numbers [9000000001, 9000000002], preferred_at 2026-11-11 05:30 UTC (11:00 IST), alternate_at 2026-11-12 09:30 UTC (15:00 IST), message stored as plain text. First submission took >4 s on a freshly restarted dev server (button showed "Sending…").
- Status: **Pass**
- Evidence: docs/qa/evidence/onboarding/connect-filled-1280.png

ONB-TC-022: Duplicate open request from same mobile

- Preconditions: None
- Steps: Submit a second request with mobile 9000000001 while PR-JM3K-TPQA is open.
- Test data: n/a
- Expected: Clear "already have your request" notice, no new row.
- Actual: Notice "We already have your request" with a link to check it; no new row in DB.
- Status: **Pass**
- Evidence: docs/qa/evidence/onboarding/connect-duplicate-1280.png

ONB-TC-023: "As soon as possible" request redirects to success

- Preconditions: None
- Steps: QA-T Reject Society, 9000000024, choose As soon as possible, Send request.
- Test data: n/a
- Expected: Redirect to /connect/success?code=...
- Actual: Redirected in 1.3 s to /connect/success?code=PR-P9DP-PUEF.
- Status: **Pass**
- Evidence: docs/qa/evidence/onboarding/connect-asap-1280.png

Connect request success / status lookup (`/connect/success`)

Screen information. Module: Public website. Role: Public (signed out). Purpose: Show the request ID after submission; otherwise look up a request by ID + mobile. Entry point: Redirect after Send request; direct URL. Previous screen: /connect. Next screen: / (Back to home) or /connect (Send a new request).

ONB-TC-009: Direct visit with no stored request shows status lookup

- Preconditions: None
- Steps: Open /connect/success in a fresh browser.
- Test data: n/a
- Expected: Lookup form (Request ID + mobile) rather than a broken page.
- Actual: "Check your request" form with Request ID, Mobile number, Check status, Send a new request, Back to home.
- Status: **Pass**
- Evidence: docs/qa/evidence/onboarding/connect-success-empty-1280.png, docs/qa/evidence/onboarding/connect-success-empty-375.png

ONB-TC-024: Success page shows request ID, society, status, schedule and next steps

- Preconditions: None
- Steps: After submission view the success page.
- Test data: n/a
- Expected: Request ID, copy button, society, status, scheduled call.
- Actual: Shows PR-P9DP-PUEF, "Copy request ID", QA-T Reject Society, Status New, Scheduled call "As soon as possible", 3 next steps.
- Status: **Pass**
- Evidence: docs/qa/evidence/onboarding/connect-success-1280.png

ONB-TC-025: Copy request ID button

- Preconditions: None
- Steps: Click "Copy request ID", read clipboard.
- Test data: n/a
- Expected: Clipboard holds the code.
- Actual: Clipboard = PR-P9DP-PUEF.
- Status: **Pass**
- Evidence: n/a

ONB-TC-026: Refresh success page keeps the data

- Preconditions: None
- Steps: Reload /connect/success?code=PR-P9DP-PUEF.
- Test data: n/a
- Expected: Same details shown.
- Actual: Same details shown after reload (session storage).
- Status: **Pass**
- Evidence: n/a

ONB-TC-027: Status lookup: invalid code format

- Preconditions: None
- Steps: Fresh browser at 375px, Request ID "XYZ", mobile 9000000001, Check status.
- Test data: n/a
- Expected: Format error.
- Actual: "Enter the request ID in the form PR-XXXX-XXXX."
- Status: **Pass**
- Evidence: n/a

ONB-TC-028: Status lookup: right code, wrong mobile

- Preconditions: None
- Steps: PR-JM3K-TPQA + 9000000099.
- Test data: n/a
- Expected: Generic not-found message (no leak).
- Actual: "We couldn't find a request with that ID and mobile number. Check both and try again."
- Status: **Pass**
- Evidence: n/a

ONB-TC-029: Status lookup: valid code (lower case) and mobile at 375px

- Preconditions: None
- Steps: pr-jm3k-tpqa + 9000000001.
- Test data: n/a
- Expected: Request status shown; no overflow at 375px.
- Actual: "Your request" status card shown; code normalised to upper case; no overflow.
- Status: **Pass**
- Evidence: docs/qa/evidence/onboarding/connect-status-lookup-375.png

Enroll (legacy) (`/enroll`)

Screen information. Module: Public website. Role: Public. Purpose: Old enrollment route, now redirects. Entry point: Direct URL. Previous screen: n/a. Next screen: /connect.

ONB-TC-008: /enroll redirects to /connect

- Preconditions: None
- Steps: Open /enroll.
- Test data: n/a
- Expected: Redirect to /connect.
- Actual: Landed on /connect (title "Connect with us | Parisar").
- Status: **Pass**
- Evidence: docs/qa/evidence/onboarding/enroll-1280.png

Login (`/login`)

Screen information. Module: Authentication. Role: Resident / Society authority (signed out). Purpose: Enter mobile number and request OTP; toggle Resident vs Society authority. Entry point: Landing "Log in", middleware redirect. Previous screen: /. Next screen: /verify.

ONB-TC-010: Login renders with Resident / Society authority toggle

- Preconditions: None
- Steps: Open /login and /login?as=authority at 1280 and 375.
- Test data: n/a
- Expected: Phone input with +91, toggle, Send OTP, Forgot PIN; authority copy when as=authority.
- Actual: Both variants render correctly; authority variant shows "Society authority sign-in" and "Authority Number" label; no overflow.
- Status: **Pass**
- Evidence: docs/qa/evidence/onboarding/login-1280.png, docs/qa/evidence/onboarding/login-authority-1280.png, docs/qa/evidence/onboarding/login-375.png

ONB-TC-013: Protected route while signed out (/setup, /import, /c/k7m2x9)

- Preconditions: None
- Steps: In a fresh browser open /setup, /import and /c/k7m2x9.

- Test data: n/a
- Expected: Redirect to /login?next=.
- Actual: Dev environment: redirected via /dev-login, which auto-signed in as 9000000005 and showed /onboarding. The production redirect to /login cannot be observed with ENABLE_DEV_ROUTES=1.
- Status: **Blocked**
- Evidence: docs/qa/evidence/onboarding/setup-signedout-1280.png, docs/qa/evidence/onboarding/console-signedout-1280.png

Verify OTP / PIN (`/verify`)

Screen information. Module: Authentication. Role: Signed out, OTP pending. Purpose: Enter 6-digit OTP, then society picker (authority), set/enter PIN. Entry point: /login Send OTP. Previous screen: /login. Next screen: /setup, /onboarding, /dashboard or console depending on account.

ONB-TC-011: Direct visit to /verify without a phone number

- Preconditions: None
- Steps: Open /verify with no query string.
- Test data: n/a
- Expected: Redirect to /login, or a clear message that no number was entered.
- Actual: OTP screen shows "Sent to +91" with no number and a running "Resend OTP in 0:59" timer; Verify button active.
- Status: **Fail**
- Evidence: docs/qa/evidence/onboarding/verify-direct-1280.png

Household invitation (public) (`/invite/[token]`)

Screen information. Module: Family invite. Role: Public / invitee. Purpose: Landing for a family invite link; asks invitee to sign in. Entry point: Shared invite link. Previous screen: n/a. Next screen: /login then /join/invite/[token].

ONB-TC-012: Invalid / truncated invite token

- Preconditions: None
- Steps: Open /invite/badtoken123.
- Test data: n/a
- Expected: Friendly invalid-link message.
- Actual: "This link is not complete. Ask the person who invited you to copy the full link again."
- Status: **Pass**
- Evidence: docs/qa/evidence/onboarding/invite-bad-1280.png, docs/qa/evidence/onboarding/invite-bad-375.png

Part 2: Core modules: screens and test cases (area `core`)

Tester: core. Environment: http://localhost:3000 (Next dev), local Supabase, Chrome headless via playwright-core outside the repo. Sessions were opened with /dev-login?as= (dev-only route that verifies OTP 123456 server-side); the OTP/PIN UI itself belongs to the onboarding area. Society under test: QA Sunrise Heights (06d44e6a-...). Switched-on features there: visitors, staff_directory, directory, polls (+ core notices, complaints, sos). New data is prefixed "QA-T ".

Counts: 34 test cases, 24 Pass, 8 Fail, 1 Blocked, 1 Not Tested. Bugs: 11.

1. Module inventory

Module	Route(s)	Sidebar (manager / resident)	Status	Evidence
Home dashboard	/dashboard	Home / Home	Testing	crawl-17-_dashboard-1280.png

Module	Route(s)	Sidebar (manager / resident)	Status	Evidence
Society dashboard (authority)	/society-dashboard	Society / -	Testing	
Society profile	/society	Society / -	Testing	
Complaints (society list)	/complaints, /complaints/new, /complaints/[id]	Services / board only	Testing	
My complaints	/my-complaints	Services / My home	Testing	
Notices	/notices, /notices/new, /notices/[id]	Communication / Communication	Testing	
Polls	/polls	Communication / Communication (feature polls)	Testing	
Bookings	/bookings, /bookings/new	Services (feature bookings; OFF for QA Sunrise Heights)	Testing	
Facility calendar	/facilities	Services (feature facility_calendar; OFF)	Testing	
Community	/community, /community/new, /community/[id], /community/moderation	Communication (feature community; OFF)	Testing	
Flat actions	/flat-actions, /flat-actions/new, /flat-actions/[id]	Services manager only (feature flat_actions; OFF)	Testing	
Visitors	/visitors	Security / My home (feature visitors)	Testing	
Guard console	/guard (outside protected group)	not in sidebar	Testing	
Staff directory / manage	/staff, /staff/manage, /staff/manage/new, /staff/manage/[id]	Security / Services (feature staff_directory)	Testing	
SOS	header button "Emergency SOS" (components/sos)	header, all roles (core feature)	Testing	
Member directory	/dashboard/directory, /dashboard/directory/[id]	Residents / Communication (feature directory)	Testing	
Join review queue	/dashboard/review-queue	Residents / -	Testing	
Society code rotation	/dashboard/code-rotation	Society / -	Testing	
Role transfer	/dashboard/role-transfer	Settings, secretary only	Testing	
Notification settings	/settings/notifications	Settings / Settings	Testing	
Grievance officer	/settings/grievance-officer	Settings / -	Testing	
Profile (+ language, logout)	/profile, header avatar menu	Settings / Settings	Testing	
My household	/household	Residents / My home	Testing	
About	/about	not in sidebar	Testing	

Module	Route(s)	Sidebar (manager / resident)	Status	Evidence
Join flow	/join/code, /join/pending, /join/profile, /join/success, /join/invite/[token]	not in sidebar (onboarding area)	Testing (signed-in reachability only)	
Legacy onboard	/onboard	not in sidebar	Testing	
Residents, approvals, import, verification, setup	/residents/*, /approvals, /import, /verification/*, /setup/*	Residents / Society	Out of core scope (onboarding area); reachability only	
Vehicles	none	none	Not Implemented	no route under apps/web/app; no nav item
Parking	none	HIDDEN_NAV_ITEMS security.parking	Not Implemented	lib/nav/sidebarNav.js HIDDEN_NAV_ITEMS
Maintenance billing / dues	none	HIDDEN_NAV_ITEMS finance.maintenance_dues	Not Implemented	sidebarNav.js
Payments	none	none (fines recorded only, CLAUDE.md "No payments")	Not Implemented	no route
Accounting	none	HIDDEN_NAV_ITEMS finance.accounting	Not Implemented	sidebarNav.js
Events	none	HIDDEN_NAV_ITEMS communication.events	Not Implemented	sidebarNav.js (platform_features "bookings" is named "Events & Bookings" but has no event entity)
Vendors	none	HIDDEN_NAV_ITEMS services.vendors, finance.vendor_payments	Not Implemented	sidebarNav.js
Documents	none	HIDDEN_NAV_ITEMS documents.society_documents	Not Implemented	sidebarNav.js
Reports	none	HIDDEN_NAV_ITEMS reports.reports	Not Implemented	sidebarNav.js
Deliveries	none (visitors module may log a delivery purpose)	none	Not Implemented as a module	no route
User / role management	/dashboard/role-transfer, society-dashboard authorities section	Settings	Partial (secretary hand-over and authority list only)	
Subscription	/society-dashboard features section (request add/remove, priced per month)	Society	Testing (request only; approval is platform admin)	
Expected visitors / staff attendance	none	HIDDEN_NAV_ITEMS security.*	Not Implemented	sidebarNav.js

2. Screens

All: Route smoke (direct URL as authority) (`many`)

- **Role(s):** secretary 14
- **Purpose:** Baseline: every route loads
- **Entry point:** direct URL
- **Previous / next screen:** -

CORE-TC-001: Authority (14) opens /dashboard by direct URL at 1280 and 375 px

- Preconditions: Signed in as 9000000014 (secretary, QA Sunrise Heights) via /dev-login
- Steps: Open http://localhost:3000/dashboard; wait for network idle; record HTTP status, final URL, h1, horizontal overflow; resize to 375 px
- Test data:
- Expected: HTTP 200, page stays on route, no horizontal scroll at 1280 or 375
- Actual: HTTP 200, final URL /onboarding, h1 "Your details and flat", overflow 0 px at 1280 and 375
- Status: **Fail**
- Evidence: docs/qa/evidence/core/crawl-14-_dashboard-1280.png, -375.png

CORE-TC-002: Authority (14) opens /society-dashboard by direct URL at 1280 and 375 px

- Preconditions: Signed in as 9000000014 (secretary, QA Sunrise Heights) via /dev-login
- Steps: Open http://localhost:3000/society-dashboard; wait for network idle; record HTTP status, final URL, h1, horizontal overflow; resize to 375 px
- Test data:
- Expected: HTTP 200, page stays on route, no horizontal scroll at 1280 or 375
- Actual: HTTP 200, final URL /society-dashboard, h1 "Society Dashboard", overflow 0 px at 1280 and 375
- Status: **Pass**
- Evidence: docs/qa/evidence/core/crawl-14-_society-dashboard-1280.png, -375.png

CORE-TC-003: Authority (14) opens /society by direct URL at 1280 and 375 px

- Preconditions: Signed in as 9000000014 (secretary, QA Sunrise Heights) via /dev-login
- Steps: Open http://localhost:3000/society; wait for network idle; record HTTP status, final URL, h1, horizontal overflow; resize to 375 px
- Test data:
- Expected: HTTP 200, page stays on route, no horizontal scroll at 1280 or 375
- Actual: HTTP 200, final URL /society, h1 "Society profile", overflow 0 px at 1280 and 375
- Status: **Pass**
- Evidence: docs/qa/evidence/core/crawl-14-_society-1280.png, -375.png

CORE-TC-004: Authority (14) opens /complaints by direct URL at 1280 and 375 px

- Preconditions: Signed in as 9000000014 (secretary, QA Sunrise Heights) via /dev-login
- Steps: Open http://localhost:3000/complaints; wait for network idle; record HTTP status, final URL, h1, horizontal overflow; resize to 375 px
- Test data:
- Expected: HTTP 200, page stays on route, no horizontal scroll at 1280 or 375
- Actual: HTTP 200, final URL /complaints, h1 "Complaints", overflow 0 px at 1280 and 375
- Status: **Pass**
- Evidence: docs/qa/evidence/core/crawl-14-_complaints-1280.png, -375.png

CORE-TC-005: Authority (14) opens /complaints/new by direct URL at 1280 and 375 px

- Preconditions: Signed in as 9000000014 (secretary, QA Sunrise Heights) via /dev-login
- Steps: Open http://localhost:3000/complaints/new; wait for network idle; record HTTP status, final URL, h1, horizontal overflow; resize to 375 px
- Test data:
- Expected: HTTP 200, page stays on route, no horizontal scroll at 1280 or 375
- Actual: HTTP 200, final URL /complaints/new, h1 "", overflow 0 px at 1280 and 375
- Status: **Pass**
- Evidence: docs/qa/evidence/core/crawl-14-_complaints_new-1280.png, -375.png

CORE-TC-006: Authority (14) opens /my-complaints by direct URL at 1280 and 375 px

- Preconditions: Signed in as 9000000014 (secretary, QA Sunrise Heights) via /dev-login
- Steps: Open http://localhost:3000/my-complaints; wait for network idle; record HTTP status, final URL, h1, horizontal overflow; resize to 375 px
- Test data:
- Expected: HTTP 200, page stays on route, no horizontal scroll at 1280 or 375
- Actual: HTTP 200, final URL /my-complaints, h1 "Complaints", overflow 0 px at 1280 and 375
- Status: **Pass**
- Evidence: docs/qa/evidence/core/crawl-14-_my-complaints-1280.png, -375.png

CORE-TC-007: Authority (14) opens /notices by direct URL at 1280 and 375 px

- Preconditions: Signed in as 9000000014 (secretary, QA Sunrise Heights) via /dev-login
- Steps: Open http://localhost:3000/notices; wait for network idle; record HTTP status, final URL, h1, horizontal overflow; resize to 375 px
- Test data:
- Expected: HTTP 200, page stays on route, no horizontal scroll at 1280 or 375
- Actual: HTTP 500, final URL /notices, h1 "Notices", overflow 0 px at 1280 and 375
- Status: **Fail**
- Evidence: docs/qa/evidence/core/crawl-14-_notices-1280.png, -375.png

CORE-TC-008: Authority (14) opens /notices/new by direct URL at 1280 and 375 px

- Preconditions: Signed in as 9000000014 (secretary, QA Sunrise Heights) via /dev-login
- Steps: Open http://localhost:3000/notices/new; wait for network idle; record HTTP status, final URL, h1, horizontal overflow; resize to 375 px
- Test data:
- Expected: HTTP 200, page stays on route, no horizontal scroll at 1280 or 375
- Actual: HTTP 200, final URL /notices/new, h1 "New Notice", overflow 0 px at 1280 and 375
- Status: **Pass**
- Evidence: docs/qa/evidence/core/crawl-14-_notices_new-1280.png, -375.png

CORE-TC-009: Authority (14) opens /polls by direct URL at 1280 and 375 px

- Preconditions: Signed in as 9000000014 (secretary, QA Sunrise Heights) via /dev-login
- Steps: Open http://localhost:3000/polls; wait for network idle; record HTTP status, final URL, h1, horizontal overflow; resize to 375 px
- Test data:
- Expected: HTTP 200, page stays on route, no horizontal scroll at 1280 or 375
- Actual: HTTP 500, final URL /polls, h1 "Polls", overflow 0 px at 1280 and 375
- Status: **Fail**
- Evidence: docs/qa/evidence/core/crawl-14-_polls-1280.png, -375.png

CORE-TC-010: Authority (14) opens /bookings by direct URL at 1280 and 375 px

- Preconditions: Signed in as 9000000014 (secretary, QA Sunrise Heights) via /dev-login
- Steps: Open http://localhost:3000/bookings; wait for network idle; record HTTP status, final URL, h1, horizontal overflow; resize to 375 px
- Test data:
- Expected: HTTP 200, page stays on route, no horizontal scroll at 1280 or 375
- Actual: HTTP 200, final URL /bookings, h1 "Bookings", overflow 0 px at 1280 and 375
- Status: **Pass**
- Evidence: docs/qa/evidence/core/crawl-14-_bookings-1280.png, -375.png

CORE-TC-011: Authority (14) opens /bookings/new by direct URL at 1280 and 375 px

- Preconditions: Signed in as 9000000014 (secretary, QA Sunrise Heights) via /dev-login

- Steps: Open http://localhost:3000/bookings/new; wait for network idle; record HTTP status, final URL, h1, horizontal overflow; resize to 375 px
- Test data:
- Expected: HTTP 200, page stays on route, no horizontal scroll at 1280 or 375
- Actual: HTTP 200, final URL /bookings/new, h1 "Request Booking", overflow 0 px at 1280 and 375
- Status: **Pass**
- Evidence: docs/qa/evidence/core/crawl-14-_bookings_new-1280.png, -375.png

CORE-TC-012: Authority (14) opens /facilities by direct URL at 1280 and 375 px

- Preconditions: Signed in as 9000000014 (secretary, QA Sunrise Heights) via /dev-login
- Steps: Open http://localhost:3000/facilities; wait for network idle; record HTTP status, final URL, h1, horizontal overflow; resize to 375 px
- Test data:
- Expected: HTTP 200, page stays on route, no horizontal scroll at 1280 or 375
- Actual: HTTP 200, final URL /facilities, h1 "Facility calendar", overflow 0 px at 1280 and 375
- Status: **Pass**
- Evidence: docs/qa/evidence/core/crawl-14-_facilities-1280.png, -375.png

CORE-TC-013: Authority (14) opens /community by direct URL at 1280 and 375 px

- Preconditions: Signed in as 9000000014 (secretary, QA Sunrise Heights) via /dev-login
- Steps: Open http://localhost:3000/community; wait for network idle; record HTTP status, final URL, h1, horizontal overflow; resize to 375 px
- Test data:
- Expected: HTTP 200, page stays on route, no horizontal scroll at 1280 or 375
- Actual: HTTP 200, final URL /community, h1 "Community", overflow 0 px at 1280 and 375
- Status: **Pass**
- Evidence: docs/qa/evidence/core/crawl-14-_community-1280.png, -375.png

CORE-TC-014: Authority (14) opens /community/new by direct URL at 1280 and 375 px

- Preconditions: Signed in as 9000000014 (secretary, QA Sunrise Heights) via /dev-login
- Steps: Open http://localhost:3000/community/new; wait for network idle; record HTTP status, final URL, h1, horizontal overflow; resize to 375 px
- Test data:
- Expected: HTTP 200, page stays on route, no horizontal scroll at 1280 or 375
- Actual: HTTP 200, final URL /community/new, h1 "New Post", overflow 0 px at 1280 and 375
- Status: **Pass**
- Evidence: docs/qa/evidence/core/crawl-14-_community_new-1280.png, -375.png

CORE-TC-015: Authority (14) opens /community/moderation by direct URL at 1280 and 375 px

- Preconditions: Signed in as 9000000014 (secretary, QA Sunrise Heights) via /dev-login
- Steps: Open http://localhost:3000/community/moderation; wait for network idle; record HTTP status, final URL, h1, horizontal overflow; resize to 375 px
- Test data:
- Expected: HTTP 200, page stays on route, no horizontal scroll at 1280 or 375
- Actual: HTTP 200, final URL /community/moderation, h1 "Moderation", overflow 0 px at 1280 and 375
- Status: **Pass**
- Evidence: docs/qa/evidence/core/crawl-14-_community_moderation-1280.png, -375.png

CORE-TC-016: Authority (14) opens /flat-actions by direct URL at 1280 and 375 px

- Preconditions: Signed in as 9000000014 (secretary, QA Sunrise Heights) via /dev-login
- Steps: Open http://localhost:3000/flat-actions; wait for network idle; record HTTP status, final URL, h1, horizontal overflow; resize to 375 px

- Test data:
- Expected: HTTP 200, page stays on route, no horizontal scroll at 1280 or 375
- Actual: HTTP 200, final URL /flat-actions, h1 "Flat Actions — Society", overflow 0 px at 1280 and 375
- Status: **Pass**
- Evidence: docs/qa/evidence/core/crawl-14-_flat-actions-1280.png, -375.png

Complaints: File a Complaint (`/complaints/new`)

- **Role(s):** Any active member with a flat (owner 17/18, tenant 19, family 20/21); authorities without a flat also reach it
- **Purpose:** Resident raises a society or member issue with optional photo
- **Entry point:** 'File a Complaint' button on /complaints or /my-complaints; dashboard My Complaints tile
- **Previous / next screen:** /complaints or /my-complaints -> (submit) toast -> /complaints (members are shown the My Complaints list)

Field testing: Type (segmented radio: Society Issue default / Member Issue); Description (textarea, min 10 trimmed chars, maxLength 1000, live counter n/1000, hint 'Please describe the issue in at least 10 characters.'); Photo (optional file input accept=image/*, client limit 10 MB, non-image rejected with 'Choose an image file (JPG, PNG or similar).'). Submit disabled while empty, <10 chars, whitespace only, or photo uploading.

Button testing: Back (to list), Society Issue / Member Issue radios, Tap to add photo, Remove photo (x), Submit Complaint (disabled until valid; shows Submitting; success toast then redirect after delay). Double-click creates exactly one row.

Navigation testing: Back link and browser back return to list; no unsaved-changes prompt when leaving with typed text (Low, see CORE-009). Direct URL signed out -> /login (see smoke).

UI checks: 1280 and 375 px: no horizontal overflow; nested

elements (CORE-008).

CORE-TC-017: Submit disabled for empty, short and whitespace-only description

- Preconditions: Owner 17 signed in, /complaints/new
- Steps: Leave empty; type 'short'; type 10 spaces; check Submit state
- Test data: '', 'short', ' '
- Expected: Submit disabled; hint shown for short text
- Actual: Disabled in all three; hint 'Please describe the issue in at least 10 characters.' and counter 5/1000
- Status: **Pass**
- Evidence: docs/qa/evidence/core/loop-01-new-form.png

CORE-TC-018: Description max length 1000

- Preconditions: same
- Steps: Type 1100 chars
- Test data: 'x' x 1100
- Expected: Capped at 1000, counter turns red
- Actual: Value length 1000, counter 1000/1000
- Status: **Pass**
- Evidence: docs/qa/evidence/core/loop-02-file-validation.png

CORE-TC-019: Non-image file rejected

- Preconditions: same
- Steps: Choose note.txt in the photo input
- Test data: note.txt (5 B, text/plain)
- Expected: Inline error, nothing uploaded

- Actual: 'Choose an image file (JPG, PNG or similar).'
- Status: **Pass**
- Evidence: docs/qa/evidence/core/loop-02-file-validation.png

CORE-TC-020: Corrupt/large image with image extension

- Preconditions: same
- Steps: Choose big.jpg (6 MB random bytes, not a real JPEG)
- Test data: big.jpg
- Expected: Rejected as not a valid image, or resized; nothing stored
- Actual: Accepted with no message and uploaded to storage (6,000,000 B object) before being replaced; content is not checked
- Status: **Fail**
- Evidence: storage.objects row .../7b1d7588-.../efc1f97e-....jpg size 6000000

CORE-TC-021: Replacing a photo removes the earlier upload

- Preconditions: same
- Steps: Attach big.jpg, then attach photo.png, submit
- Test data:
- Expected: Only the final photo remains in storage
- Actual: attachments has 1 row (png) but the replaced 6 MB jpg stays in storage.objects as an orphan
- Status: **Fail**
- Evidence: SQL: storage.objects for complaint 7b1d7588

CORE-TC-022: Owner files society complaint with photo (core loop step 1)

- Preconditions: Owner 17
- Steps: Society Issue, valid description, attach photo.png (64x64), Submit
- Test data: 'QA-T Lift in A Wing stops between floors 2 and 3 since morning '
- Expected: Toast, redirect to list, row + attachment saved
- Actual: Toast shown, redirected to /complaints; complaints row 7b1d7588 kind=society status=open; attachments row png 177 B
- Status: **Pass**
- Evidence: docs/qa/evidence/core/loop-03-photo-attached.png, docs/qa/evidence/core/loop-04-submitted-toast.png

CORE-TC-023: Double-click Submit creates one complaint

- Preconditions: Owner 18
- Steps: Member Issue, valid text, double-click Submit
- Test data: 'QA-T Water seepage from ceiling ...'
- Expected: Exactly one row
- Actual: 1 row (SQL count)
- Status: **Pass**
- Evidence: SQL

Complaints: Complaints list (board) / My Complaints (member) (`/complaints, /my-complaints`)

- **Role(s):** Board/authority see all society complaints with Open/Resolved tabs; members are shown 'My Complaints' (own only) at the same /complaints URL
- **Purpose:** Track complaints and status
- **Entry point:** Sidebar Services > Complaints (manager/board) or My home > My Complaints
- **Previous / next screen:** Dashboard -> list -> /complaints/[id]

Field testing: Tabs Open / Resolved (board). No search, filter by type, or pagination controls visible (list loads 30, cursor in API).

Button testing: Dashboard back link, File a Complaint, card click -> detail.

Navigation testing: Card click navigates to detail; reload keeps state.

UI checks: Empty states: board 'All quiet for now / No complaints have been filed by residents.', member 'File your first complaint anytime.' Realtime insert does not appear (CORE-005).

CORE-TC-024: Authority list receives a new complaint in realtime

- Preconditions: Authority 14 (and 15) have /complaints open; owner files a complaint
- Steps: Wait 6 s (run 1) and 12 s (run 2) without reload
- Test data:
- Expected: New card appears at top without refresh
- Actual: Not shown after 12 s; appears only after reload
- Status: **Fail**
- Evidence: docs/qa/evidence/core/loop-05-authority-list-realtime.png, docs/qa/evidence/core/rt-01-authority-list-12s-after-insert.png

CORE-TC-025: Authority list shows new complaint after reload

- Preconditions: same
- Steps: Reload /complaints
- Test data:
- Expected: Card with text, 'Filed by (A Wing-101)', Open
- Actual: As expected
- Status: **Pass**
- Evidence: docs/qa/evidence/core/loop-06-authority-detail.png

CORE-TC-029: Reporter's list status updates (realtime and after reload)

- Preconditions: Owner 17 on My Complaints while authority resolves
- Steps: Wait 5 s; then reload
- Test data:
- Expected: Status Resolved
- Actual: Stays 'Open' live; shows 'Resolved' and 'Owned by QA Contact One' after reload
- Status: **Fail**
- Evidence: docs/qa/evidence/core/loop-09-owner-resolved.png, docs/qa/evidence/core/loop-10-owner-my-complaints.png

Complaints: Complaint detail and response (`/complaints/[id]`)

- **Role(s):** Reporter (read-only + trail), board (claim/respond), other board after claim (read-only 'Owned by' banner)
- **Purpose:** Board member claims and responds; status trail visible to reporter
- **Entry point:** Card on complaints list
- **Previous / next screen:** list <- Back

Field testing: Free-text note textarea (optional, maxLength 500, counter).

Button testing: Response chips Checking / Will resolve soon / Need more info / Resolved (first click claims atomically; response kind becomes status). Photo thumbnail opens dialog.

Navigation testing: Back to list; non-permitted id shows not-found card.

UI checks: Authority attribution shows flat as '(—)' (CORE-010). Not-found card shows two contradictory messages (CORE-011).

CORE-TC-026: Authority claims complaint with 'Checking' and note (core loop step 2)

- Preconditions: Authority 14 on detail
- Steps: Type note, click Checking
- Test data: 'QA-T Technician called, checking today'
- Expected: Status Checking, 'You own this complaint.', trail entry with note
- Actual: As expected; complaint_responses row checking with note
- Status: **Pass**
- Evidence: docs/qa/evidence/core/loop-07-authority-claimed.png

CORE-TC-027: Owner of complaint changes status to Resolved

- Preconditions: Authority 14 owns complaint
- Steps: Click Resolved
- Test data:
- Expected: status=resolved
- Actual: DB status resolved; second response row
- Status: **Pass**
- Evidence: SQL complaints 7b1d7588

CORE-TC-028: Reporter sees the new response in realtime (core loop step 3)

- Preconditions: Owner 18 has detail open; authority 15 responds 'Will resolve soon' with note
- Steps: Wait 12 s
- Test data:
- Expected: Trail entry appears and status badge changes to 'Will resolve soon'
- Actual: Trail entry appears live, but the status badge still says 'Open' until reload
- Status: **Fail**
- Evidence: docs/qa/evidence/core/rt-03-owner-detail-12s-after-response.png

CORE-TC-030: Second board member sees owned-by lock

- Preconditions: Authority 16 opens complaint owned by 15
- Steps: Open detail
- Test data:
- Expected: No response chips; 'Owned by ...' banner
- Actual: 'Owned by QA Authority One (—). They are managing this complaint.'; no chips
- Status: **Pass**
- Evidence: docs/qa/evidence/core/rt-04-other-authority-owned-banner.png

CORE-TC-031: Reporter cannot respond

- Preconditions: Owner on own complaint detail
- Steps: Look for response chips / note box
- Test data:
- Expected: Absent
- Actual: Absent (no #complaint-free-text)
- Status: **Pass**
- Evidence: docs/qa/evidence/core/rt-03-owner-detail-12s-after-response.png

CORE-TC-032: Unrelated member opens another flat's Member Issue by URL

- Preconditions: Tenant 19 (A-102) opens complaint 52923cef filed by owner 18 (A-102)
- Steps: Direct URL
- Test data:
- Expected: Access denied/not found, no data
- Actual: 'Complaint not found' card; no data leaked. Also shows contradictory 'Check your connection' line
- Status: **Pass**
- Evidence: docs/qa/evidence/core/rt-02-tenant-view-other-member-complaint.png

CORE-TC-033: Complaint photo visible on detail

- Preconditions: Owner 17 complaint with png
- Steps: Open detail as authority
- Test data:
- Expected: Thumbnail and enlarge dialog
- Actual: Not verified: script navigation raced; attachment row exists
- Status: **Not Tested**
- Evidence:

CORE-TC-034: Resident notified of status change (push)

- Preconditions: Responses created
- Steps: SQL push_outbox
- Test data:
- Expected: Push delivered to reporter
- Actual: push_outbox rows complaint_response x2 created but processed_at NULL (no push worker/FCM locally). No in-app notification inbox exists on web; the only signal is the live trail entry
- Status: **Blocked**
- Evidence: SQL push_outbox

3. Bugs (summary)

ID	Sev	Screen	Title
CORE-001	High	/notices	Notices list returns HTTP 500 on server render though the page body shows the empty state
CORE-002	High	/polls	Polls list returns HTTP 500 on server render
CORE-003	High	/dashboard	Authority without a flat is redirected from /dashboard to /onboarding ("Your details and flat")
CORE-004	Medium	/bookings, /facilities, /community, /flat-actions	Switched-off features are only hidden from the sidebar; their pages open by direct URL
CORE-005	High	/complaints	New complaints do not appear in the board list in realtime
CORE-006	High	/complaints/[id], /my-complaints	Reporter's status badge does not update live when board responds (core loop)
CORE-007	Medium	/complaints/new	Replaced or abandoned complaint photos stay in storage; image content not validated
CORE-008	Low	/complaints and others	Nested landmarks (layout main#main-content wraps page)
CORE-009	Low	/complaints/new	No unsaved-changes warning when leaving a typed complaint
CORE-010	Low	/complaints/[id]	Authority responses show flat as '(—)'
CORE-011	Low	/complaints/[id]	Not-found card also shows 'Check your connection' error

Full details: `docs/qa/data/bugs-core.json`.

4. Not tested and why

- Session was interrupted once; owner (17) crawl log was lost (screenshots kept) and is being re-run.

Part 3: Screens not executed in this pass

These screens exist in the code, but nobody exercised them screen-by-screen in the browser in this QA pass. That's because testing time ran out after repeated session interruptions. Each one has test cases ready to run. Every case here has status **Not Tested**.

Where a screen was browser-tested during the onboarding build on 7 November 2026, the screenshot is named under "Earlier evidence" in `docs/onboarding/screenshots/`. That earlier evidence is **not** a pass for this QA cycle: re-run the cases.

Many of the server functions behind these screens **were** tested at the API level in this pass, by role and across societies. See `PARISAR_API_DATABASE_TESTING.md` and `PARISAR_ROLE_PERMISSION_TESTING.md`. The browser cases below check the screens on top of those functions.

Accounts:

- Platform admin: 9000000030.
- Authority (QA Sunrise Heights): 9000000014.
- Owner: 17. Tenant: 19. Household member: 20. Family member: 21.
- Guard (QA-T Lotus Society): 9000000006.
- Chairman (QA-T Lotus Society): 9000000027.
- OTP for all accounts: `123456`.

Common checks for every screen below, run once per screen in addition to its own cases:

ID suffix	Check	Expected
-C1	Open the route signed out	Redirect to `/login?next=<route>`
-C2	Open as a role that should not see it (see role matrix)	Refused: redirect or a "not allowed" state, and no data shown
-C3	Browser refresh	Same state reloads; no duplicate submission
-C4	Browser back after a successful save	No resubmission; the list shows the saved item once
-C5	Widths 375, 768, 1280 px	No horizontal scroll; tap targets at least 44 px; text not clipped
-C6	Network offline during save (DevTools)	Error message shown, form keeps its values, button re-enabled
-C7	Keyboard only	Every control reachable by Tab, visible focus ring, Enter submits, Esc closes dialogs

---

A. Platform admin console (`/c/k7m2x9`), role: platform admin (30)

Purpose: Parisar staff manage connect requests, register societies, features and billing. **Entry:** OTP login as 30. **Earlier evidence:** `admin-*.png`.

Fields (Register Society):

- Society name (required, 2 to 120 characters)
- Society type (select)
- Registration number (optional, unique per state)
- Registration date (date)
- Official email (email format)
- Official phone (landline allowed)
- Street address (required, at least 5 characters)

- Landmark
- Area or locality (required)
- City (required)
- State (required, select)
- PIN code (required, 6 digits)
- Country (required, default India)
- Authorities list (name 2 to 80 characters, 10-digit mobile starting 6 to 9, at least one, no duplicates)
- Feature toggles (from the catalogue)

ID	Test	Steps	Expected
ADM-TC-01	Overview metrics	Open console Overview	Total societies, active societies, pending requests, pending calls and total residents match `select` counts in the DB
ADM-TC-02	Request search	Requests: search by society name, by mobile, by request code	Only matching rows; clearing restores all
ADM-TC-03	Request filters and pagination	Filter by each status and by "submitted within"; page forward and back	Counts match the DB; page controls disable at the ends
ADM-TC-04	View details	Open a request	Drawer shows contact, email, every authority number, slots, message and history
ADM-TC-05	Call and Mark called	Click Call, then Mark called	`tel:` link opens; status becomes called and history gains an entry
ADM-TC-06	Reschedule validation	Reschedule with a past date, then a valid future slot	Past date refused with a message; valid slot saved, status rescheduled
ADM-TC-07	Reject	Reject with an empty reason, then with a reason; cancel once	Empty reason blocked; confirm dialog; status rejected; cancel changes nothing
ADM-TC-08	Register prefill	Register Society from a request	Society name, contact and authority numbers prefilled from the request
ADM-TC-09	Register validation	Submit with each required field empty; PIN 5 digits; bad email; duplicate authority mobile	Field-level errors; nothing saved
ADM-TC-10	Register success	Fill valid data and submit	Result screen shows name, generated code, Copy button and registration status; request becomes registered
ADM-TC-11	Code copy and uniqueness	Copy the code; register a second society	Clipboard holds the code; codes differ; `society_codes.code` unique in the DB
ADM-TC-12	Feature toggles	Turn a feature off for a society, then sign in as its member	Sidebar item hidden; also try the route directly (known bug CORE-004: it still opens)
ADM-TC-13	Double submit	Double-click Register	One society created
ADM-TC-14	Sales role	Sign in as a sales user	Billing, payments, list prices and appoint buttons absent

B. Authority first login (`/login`, then `/verify`), role: authority

Earlier evidence: `login-authority-*.png`, `verify-*.png`.

ID	Test	Steps	Expected
AUTH-TC-01	Authority toggle	On `/login` choose Society authority, enter 9000000027, Send OTP	OTP screen shows the number
AUTH-TC-02	Unknown number	Authority toggle with a number not on any authority list	After OTP: no society offered, no society name revealed before OTP
AUTH-TC-03	Wrong OTP	Enter 111111	Error; can retry; lockout after the configured attempts

ID	Test	Steps	Expected
AUTH-TC-04	Resend OTP	Click Resend before and after the timer	Disabled until the timer ends, then sends again
AUTH-TC-05	Expired OTP	Wait past expiry (local config), then enter the code	Expired message
AUTH-TC-06	Several societies	Authority listed in two societies	Picker lists both; choosing one opens that society
AUTH-TC-07	Setup incomplete	Authority of a new society	Lands on `/setup`
AUTH-TC-08	Setup complete, no flat	Authority who finished setup	Lands on personal onboarding (see CORE-003: `/dashboard` redirects there too)
AUTH-TC-09	PIN set and use	Set a PIN, sign out, sign in with mobile and PIN	PIN login works; wrong PIN shows attempts left

C. Setup wizard (`/setup`), role: authority

Fields:

- Wing: name (required), code (required, unique in the society), floors (required, 1 or more)
- Floor: number (required), name, flat count (required)
- Flat: number (required, unique in the wing), type, area, bedrooms, parking slot, status (occupied, vacant, under construction, maintenance)

Earlier evidence: `setup-wizard-*.png`.

ID	Test	Steps	Expected
SET-TC-01	Step 1 prefill	Open step 1	Registration details shown read-only; message to contact Parisar to edit
SET-TC-02	Wing required fields	Continue with an empty wing name, code or floors	Errors per field; cannot continue
SET-TC-03	Duplicate wing code	Add two wings with code A	Second refused with a duplicate message
SET-TC-04	Floors	Add floors; enter a negative or non-numeric floor number; a duplicate floor number	Invalid and duplicate refused
SET-TC-05	Flat bulk generation	Generate flats for a floor with a flat count of 4	4 flats created with sequential numbers
SET-TC-06	Flat count mismatch	Floor says 4 flats; delete one flat	Warning or count updates; record actual behaviour
SET-TC-07	Duplicate flat	Two flats 101 in one wing	Refused
SET-TC-08	Previous and Continue	Go forward to step 4 and back to step 1	All entered data still present
SET-TC-09	Save Draft and resume	Save Draft, sign out, sign in	Wizard reopens at the saved step with the data
SET-TC-10	Skip optional	Skip step 5	Allowed; Complete Setup enabled
SET-TC-11	Complete with nothing	Try Complete Setup with no wing, floor or flat	Refused (at least one of each required)
SET-TC-12	Complete	Complete with valid structure	Success; `societies.setup_completed_at` set; dashboard reachable

ID	Test	Steps	Expected
SET-TC-13	Delete with confirmation	Delete a wing that has flats	Confirmation dialog; cascade behaviour as designed; cancel keeps it

D. Excel import (`/import`), role: authority

Earlier evidence: `import-*.png`.

ID	Test	Steps	Expected
IMP-TC-01	Template	Download Template	.xlsx with columns Society Code, Wing, Floor, Flat, Full Name, Resident Type, Mobile, Email, Family Member, Relationship, Vehicle Number
IMP-TC-02	Valid file	Upload 10 valid rows	Preview: 10 total, 10 valid, 0 errors
IMP-TC-03	Wrong format	Upload .csv, .pdf, renamed .txt	Refused with a format message
IMP-TC-04	Empty file	Upload the template with no rows	"No rows" message; nothing imported
IMP-TC-05	Missing column	Delete the Mobile column	Refused, naming the missing column
IMP-TC-06	Bad data	Rows with a 9-digit mobile, wrong society code, unknown wing, floor or flat, bad resident type	Each row flagged with its own error message
IMP-TC-07	Duplicates	Same mobile twice in the file; a mobile already a member	Duplicate errors or warnings per row
IMP-TC-08	Several residents per flat	2 owners and a tenant on one flat	Accepted or warned per the rules; record behaviour
IMP-TC-09	Formula injection	Cell `=HYPERLINK("http://x","y")` in a name	Error report cell is neutralised (starts with an apostrophe)
IMP-TC-10	Error report	Download Error Report	.xlsx lists only invalid rows with messages
IMP-TC-11	Import valid only	Import Valid Records	Only valid rows created as pending verification; DB count equals the valid count
IMP-TC-12	Cancel	Cancel after preview	Nothing imported; batch marked cancelled
IMP-TC-13	Large file	1,500 rows	Completes or shows the row limit; UI stays responsive; record the time

E. Resident verification (`/verification`, `/verification/admin`)

Earlier evidence: `resident-verification-*.png`.

ID	Test	Steps	Expected
VER-TC-01	Own record only	Imported resident logs in	Sees only their own imported details
VER-TC-02	Everything correct	Click Everything Is Correct	Status verified; membership created once
VER-TC-03	Edit details	Submit a correction	Status needs correction; admin sees the change
VER-TC-04	Report incorrect	Report with a reason	Status rejected or flagged; admin notified in the list
VER-TC-05	Admin counts and filters	Admin opens `/verification/admin`	Counts per status match the DB; filters work
VER-TC-06	Admin approve or reject a correction	Decide a correction	Status updates; resident sees the result
VER-TC-07	Re-submission	Rejected resident submits again	Allowed; history kept

F. Personal onboarding (`/onboarding`, `/onboarding/status`)

Fields:

- Society code (required)
- Wing, floor and flat dropdowns from the DB (required; no free text)
- Name
- Resident type: owner, tenant or family member
- Owner: primary or co-owner, owner since, membership number, proofs
- Tenant: move-in date (required), expected move-out, lease start and end (required), owner name and mobile, documents after registering
- PIN

Not implemented from the brief: middle name, profile photo, date of birth, gender, police verification as a separate field. Confirm the exact list against the form.

Earlier evidence: `onboarding-*.png`.

ID	Test	Steps	Expected
ONBD-TC-01	Invalid society code	Enter a wrong code	Clear error; attempts throttled
ONBD-TC-02	Dropdowns are DB-backed	Pick wing, then floor, then flat	Each list filtered by the previous choice; taken flats marked
ONBD-TC-03	Owner journey	Complete as owner with proofs	Membership active or pending as designed; proofs listed
ONBD-TC-04	Second owner	Another person registers as co-owner of the same flat	Allowed; both owners visible on the household page
ONBD-TC-05	Tenant journey	Register as tenant with lease dates	Status page shows the chain: registered, owner, society, moved in
ONBD-TC-06	Tenant date rules	Lease end before lease start; move-in empty	Refused with field errors
ONBD-TC-07	Tenant documents	Upload a rental agreement (PDF), then a 15 MB file and an .exe	PDF accepted; others refused
ONBD-TC-08	Back and forward	Go back from step 3 to step 1 and forward	Values kept

ID	Test	Steps	Expected
ONBD-TC-09	Refresh mid-wizard	Refresh on step 2	Resumes or restarts cleanly; no duplicate membership

G. Approvals (`/approvals`), roles: owner, authority

ID	Test	Steps	Expected
APR-TC-01	Owner approves tenant	Owner 17 approves a pending tenant of their flat	Step moves to society approval
APR-TC-02	Owner rejects	Reject with a reason	Tenant sees rejected with the reason
APR-TC-03	Society approves	Authority approves	Tenant becomes active; appears in `/residents/tenants`
APR-TC-04	Self-approval	Tenant tries to approve their own request (API)	Refused (`CANNOT_DECIDE_OWN_REQUEST`)
APR-TC-05	Household requests	Same-flat request appears to the owner with only the last 4 digits of the phone	No full phone shown

H. Same-flat household (`/household`) and family invite (`/invite/[token]`, `/join/invite/[token]`)

Earlier evidence: `household-*.png`, `invite-*.png`.

ID	Test	Steps	Expected
HH-TC-01	Existing household found	New user picks a flat that has residents	"Are you already part of this household?" with masked names only
HH-TC-02	Yes, continue	Answer Yes	Access request created; no access until approved
HH-TC-03	No	Answer No	Offered another flat or asked to get an invite; nothing created
HH-TC-04	Owner approves	Owner approves the request	User linked to the flat; one membership row; no duplicate resident
HH-TC-05	Knowing the flat is not enough	Request access to a flat without approval	No data and no access
HH-TC-06	Create invite	Owner adds a family member (relationship required)	Invite link shown with text saying nothing was sent automatically
HH-TC-07	Accept invite	Invitee opens the link, signs in, accepts	Linked to the flat as family member; profile completion shown
HH-TC-08	Invalid, used or expired token	Open a random token, a used one, one older than 14 days	Clear invalid message; nothing revealed
HH-TC-09	Wrong phone	Invite bound to phone A, opened by phone B	Refused

I. Residents lists (`/residents/owners|tenants|family`), role: authority

ID	Test	Steps	Expected
RES-TC-01	Lists and counts	Open each tab	Counts equal the DB; search and status filter work
RES-TC-02	Unknown slug	`/residents/unknown`	404 page
RES-TC-03	Pagination	More than one page of residents	Pages correctly

J. Staff (`/staff/manage`, `/staff/manage/new`, `/staff/manage/[id]`, `/staff`)

Fields:

- First name (required), last name
- Mobile (required)
- Email
- Staff type (required): security, plumber, electrician, cleaner, gardener, maintenance staff or other
- Joining date
- Employee ID
- Vendor
- Shift
- Emergency contact
- ID proof

Earlier evidence: `staff-*.png`.

ID	Test	Steps	Expected
STF-TC-01	Create validation	Save with no name, bad mobile, no type	Field errors
STF-TC-02	Create	Save valid staff	Appears in the list; filter by type works
STF-TC-03	Edit	Change shift	Saved and shown
STF-TC-04	ID proof	Upload a JPG, remove it with confirmation	Uploaded, then removed
STF-TC-05	Resident view	Owner opens `/staff`	Directory only, no edit controls, no private details
STF-TC-06	No login	Try to log in with a staff mobile	Not a resident or guard; no access

K. Core modules not executed screen-by-screen

These routes loaded at both 375 and 1280 px with no overflow in the route smoke test (CORE-TC-002 to 016), except `/notices` and `/polls`, which returned HTTP 500 (CORE-001, CORE-002). Their create, update and delete actions were not run in the browser in this pass. Notices, polls, bookings, visitors and SOS were tested at the API level (`PARISAR_API_DATABASE_TESTING.md`).

ID	Screen	Test	Expected
NOT-TC-01	Notices `/notices/new`	Post a notice with a title, body and attachment as authority	Appears in the list for all members; attributed with name and flat
NOT-TC-02	Notices `/notices/[id]`	Member opens it	Read-only; attachment downloads
POL-TC-01	Polls `/polls`	Authority creates a poll; two members vote; close it	One vote per member; results are an aggregate only; closed poll refuses votes
BKG-TC-01	Bookings `/bookings/new`	Request an amenity slot; approver approves; request the same slot again	Overlap refused (`slot_taken`)
FAC-TC-01	Facility calendar `/facilities`	Add and delete an event	Shown on the calendar; delete asks for confirmation
COM-TC-01	Community `/community`	Post, comment, report a post; moderator takes it down and restores it	Each state visible to the right people
FLA-TC-01	Flat actions `/flat-actions/new`	Issue a warning and a fine to a flat; resident acknowledges	Resident sees it; fine is recorded only (no payment)
VIS-TC-01	Visitors `/visitors`	Guard logs a visitor; resident approves or denies	Status updates for both; note API-002, where other flats can read the log

ID	Screen	Test	Expected
GRD-TC-01	Guard console `/c/g8s4muv`	Guard: New visitor, flat picker, large buttons on a tablet	Simple flow; 44 px or larger targets
SOS-TC-01	SOS (header button)	Raise an SOS for each audience; resolve it	Right audience notified; note API-003, where a guard cannot resolve guard-addressed SOS
DIR-TC-01	Directory `/dashboard/directory`	Search members; open one; reveal a phone	Phone hidden until the audited reveal; reveal logged
RQ-TC-01	Review queue `/dashboard/review-queue`	Approve and reject pending joins	Membership activated or rejected
CODE-TC-01	Code rotation `/dashboard/code-rotation`	Rotate the code; join with the old code	Old code refused, new code works
RT-TC-01	Role transfer `/dashboard/role-transfer`	Secretary transfers to a member with typed confirmation	Roles swap; old secretary loses manager menus
SET-N-01	Notification settings	Change toggles and the daily cap	Saved; cap 0 refused
GO-TC-01	Grievance officer	Set the officer	Shown to residents
PRO-TC-01	Profile and language	Change the language to Hindi and Marathi; log out	UI translated; logout ends the session and back navigation does not show protected data

Parisar: Role and Permission Testing

Area key: `roles`. Tester: roles-api. Last updated: 2026-11-10 10:02 UTC. Environment: local Supabase (http://127.0.0.1:54321), web dev server http://localhost:3000, branch `feat/saas-onboarding`.

Test cases: 43. Passed: 43. Failed: 0. Blocked: 0. Not tested: 0.

1. How roles really exist in code

Parisar has no single "role" column. Five separate mechanisms decide what a person can do:

Mechanism	Storage	Values	Grants a login?	Drives permissions?
Platform role	`platform_admins.role` (enum `platform_role`)	`admin`, `sales`, `staff`	Yes (OTP)	Yes: `is_platform_admin()`, `is_platform_admin_or_sales()`; console at `/c/<routeId>`
Membership role	`society_memberships.role` (enum `membership_role`)	`member`, `board_member`, `co_secretary`, `secretary`	Yes (OTP)	Yes: every RLS policy, every society RPC, JWT claim `role` from `inject_society_claims`
Society title	`society_memberships.society_title`	`resident`, `chairman`, `secretary`, `treasurer`, `committee_member` (NULL = default)	No (label)	Only through the role it maps to: resident→member, committee_member→board_member, treasurer→co_secretary, secretary→secretary, chairman→secretary. Set by `set_member_society_title` (live secretary only)
Resident type	`society_memberships.resident_type`	`owner`, `tenant`, `family_member`	No (label)	Some RPCs check it: owner of flat decides tenant/household requests, `owner_save_my_details`, `family_invite_create` (owner or tenant)
Authority	`society_authorities` (phone list per society)	claimed / unclaimed	Through OTP on the listed phone	Claiming makes the membership `secretary`; Society Dashboard shown to claimed authorities
Gate guard	`society_guards`	active / revoked	Yes (OTP)	`security_dashboard`, `guard_create_visit`, `/c/g8s4muv`. No membership row
Staff record	`society_staff` + `society_staff_details`	category `security`, `plumber`, `electrician`, `cleaner`, `gardener`, `maintenance_staff`, `other` (older `maid`, `driver`, `cook`)	**No**	None. A directory entry only

Web routing: `resolveCallerRole()` checks platform role first, then active guard, then membership (`apps/web/lib/auth/callerRole.js`). Platform roles and guards land on `/c/<routeId>` (admin `k7m2x9`, sales `p4v8qd`, staff `t6r3wz`, security `g8s4muv`, from `packages/api-client/src/roles.js`); secretary, co_secretary, board_member and member land on `/dashboard`. The sidebar is built by `apps/web/lib/nav/sidebarNav.js`: managers (`secretary`, `co_secretary`) get the admin groups; `board_member` gets the resident groups plus all complaints; Role Transfer is secretary only. Items are also hidden when the society feature is off.

2. The brief's 15 roles mapped to code

#	Brief role	Exists as	Login?	Notes
1	Platform Admin	`platform_admins.role = admin`	Yes	Account 9000000030

#	Brief role	Exists as	Login?	Notes
2	Sales	`platform_admins.role = sales`	Yes	Created by admin via `admin_create_platform_user`; no billing/payment data
3	Platform staff (support)	`platform_admins.role = staff`	Yes	Staff console `/c/t6r3wz` (profile only)
4	Chairman	title `chairman` → role `secretary`; also an authority	Yes	Same permissions as secretary
5	Secretary	role `secretary` (title `secretary` or NULL)	Yes	Only role that may set titles and transfer secretary
6	Treasurer	title `treasurer` → role `co_secretary`	Yes	Manager permissions; no finance module exists
7	Committee member	title `committee_member` → role `board_member`	Yes	Can respond to complaints, post notices; no setup/import
8	Owner	`resident_type = owner`, role `member`	Yes	
9	Tenant	`resident_type = tenant`, role `member`	Yes	Joins through the tenant chain
10	Family member	`resident_type = family_member`, role `member`	Yes	Via family invite or household request
11	Security guard	`society_guards` row	Yes	Added by a manager with `secretary_add_guard`, claimed with `claim_guard`
12	Plumber	`society_staff.category = plumber`	**No**	Staff record only
13	Electrician	`society_staff.category = electrician`	**No**	Staff record only
14	Cleaner / housekeeping	`society_staff.category = cleaner`	**No**	Staff record only
15	Gardener / maintenance staff	`society_staff.category = gardener / maintenance_staff`	**No**	Staff record only

3. Test accounts

Phone	Role under test	Society	Created by this tester?
9000000030	Platform admin	none	No (existing, used for registration and console)
9000000027	Chairman / authority (secretary)	QA-T Lotus Society (society B)	Yes
9000000003	Treasurer (co_secretary)	QA-T Lotus Society	Yes
9000000004	Committee member (board_member)	QA-T Lotus Society	Yes
9000000006	Security guard	QA-T Lotus Society	Yes
9000000007	Plain member (owner); later also sales	QA-T Lotus Society	Yes
9000000014-16	Secretary/authority (read only)	QA Sunrise Heights (society A)	No
9000000017-21	Owner, tenant, family (read only)	QA Sunrise Heights	No

No PIN was set on any account by this tester (API sign-in by OTP does not ask for one).

4. Matrices

4.1 Role x screen visibility (sidebar)

Source: derived from `apps/web/lib/nav/sidebarNav.js` (MANAGER_GROUPS for secretary and co_secretary, RESIDENT_GROUPS for board_member and member, `secretaryOnly` for Role Transfer) and `resolveCallerRole()`.

Items with a feature key appear only when that feature is on for the society. Sidebar visibility is **not** a security control: see CORE-004 (switched-off feature pages still open by direct URL). Server-side enforcement is what section 4.2 and 5 test.

Screen (sidebar item)	Secretary / Chairman	Treasurer (co_secretary)	Committee member (board_member)	Owner / Tenant / Family (member)	Security guard	Platform admin
Home `/dashboard`	Yes	Yes	Yes	Yes	No	No
Society Dashboard `/society-dashboard`	Yes	Yes	No	No	No	No
Society profile `/society`	Yes	Yes	No	No	No	No
Setup wizard `/setup`	Yes	Yes	No	No	No	No
Society code `/dashboard/code-rotation`	Yes	Yes	No	No	No	No
Owners / Tenants / Family `/residents/*`	Yes	Yes	No	No	No	No
Import `/import`	Yes	Yes	No	No	No	No
Verification admin `/verification/admin`	Yes	Yes	No	No	No	No
Approvals `/approvals`	Yes	Yes	No	No	No	No
Join requests `/dashboard/review-queue`	Yes	Yes	No	No	No	No
My household `/household`	Yes	Yes	Yes	Yes	No	No
Visitors `/visitors` (feature visitors)	Yes	Yes	Yes	Yes	No	No
Staff management `/staff/manage` (feature staff_directory)	Yes	Yes	No	No	No	No
Staff directory `/staff` (feature staff_directory)	Yes	Yes	Yes	Yes	No	No
Complaints, all `/complaints` (feature complaints)	Yes	Yes	Yes	No	No	No
My complaints `/my-complaints`	Yes	Yes	Yes	Yes	No	No
Facility calendar `/facilities` (feature facility_calendar)	Yes	Yes	Yes	Yes	No	No
Bookings `/bookings` (feature bookings)	Yes	Yes	Yes	Yes	No	No
Flat actions `/flat-actions` (feature flat_actions)	Yes	Yes	No	No	No	No
Notices `/notices`	Yes	Yes	Yes	Yes	No	No
Polls `/polls` (feature polls)	Yes	Yes	Yes	Yes	No	No
Community `/community` (feature community)	Yes	Yes	Yes	Yes	No	No
Directory `/dashboard/directory` (feature directory)	Yes	Yes	Yes	Yes	No	No
Notification settings	Yes	Yes	Yes	Yes	No	No
Grievance officer	Yes	Yes	No	No	No	No
Role transfer `/dashboard/role-transfer`	Secretary/Chairman only	No	No	No	No	No

Screen (sidebar item)	Secretary / Chairman	Treasurer (co_secretary)	Committee member (board_member)	Owner / Tenant / Family (member)	Security guard	Platform admin
Profile	Yes	Yes	Yes	Yes	No	No
Guard console `/c/g8s4muv`	No	No	No	No	Yes	No
Platform console `/c/k7m2x9`	No	No	No	No	No	Yes

Staff (plumber, electrician, cleaner, gardener, maintenance staff) have no login and therefore no screens.

4.2 Role x API authorization

Executed against the live local API with one real session per role; the full results are the TC-ROLE-1xx rows in section 5 (each row lists the outcome for anon, platform admin, chairman, treasurer, committee member, member, guard, and the secretary, owner, tenant and family member of a **different** society). Summary: 96 role-by-RPC result rows, 92 passed, 4 failed. The 4 failures are test-harness problems, not product defects: TC-ROLE-107 was run twice with wrong parameters (PostgREST could not find the function signature, then `INVALID_RESIDENT_TYPE` from a bad argument), TC-ROLE-117 expected a different error code for non-members (`NO_SOCIETY`, which is still a refusal), and TC-ROLE-015 compared a claim field name the harness abbreviated. They should be re-run with corrected scripts. Product defects found by this tester come from the workflow tests and are listed in section 6.

4.3 Direct URL access (browser)

Signed-out access to every protected route redirects to `/login` (security tests). Signed-in access by the wrong role: manager-only pages refuse non-managers through their server RPCs (role matrix above), but feature-gated pages are reachable when the feature is switched off (CORE-004). A full browser crawl of every route for every role was **not executed** in this pass; see the screen-by-screen document, section "Screens not executed in this pass".

5. Test cases

Role x RPC authorization

ID	Title	Expected	Actual	Status
TC-ROLE-001	member sets a title	ONLY_SECRETARY_CAN_SET_TITLE	400 {"code":"P0001","details":null,"hint":null,"message":"ONLY_SECRETARY_CAN_SET_TITLE"}	Pass
TC-ROLE-002	secretary sets unknown title	INVALID_TITLE	400 {"code":"P0001","details":null,"hint":null,"message":"INVALID_TITLE"}	Pass
TC-ROLE-003	secretary of B sets title on member of A	TARGET_NOT_IN_SOCIETY	400 {"code":"P0001","details":null,"hint":null,"message":"TARGET_NOT_IN_SOCIETY"}	Pass
TC-ROLE-004	secretary makes 03 treasurer	200 role co_secretary	200 {"role":"co_secretary","user_id":"5ab3844b-9d41-4688-9bfc-30a10975d752","society_title":"treasurer"}	Pass
TC-ROLE-005	secretary makes 04 committee member	200 role board_member	200 {"role":"board_member","user_id":"e6f23b21-acfe-4c4f-abba-d7366b6b1cc7","society_title":"committee_member"}	Pass

ID	Title	Expected	Actual	Status
TC-ROLE-006	secretary demotes self to treasurer	CANNOT_CHANGE_OWN_ROLE	400 {"code":"P0001","details":null,"hint":null,"message":"CANNOT_CHANGE_OWN_ROLE"}	Pass
TC-ROLE-007	secretary sets own title chairman (role unchanged)	200 role secretary	200 {"role":"secretary","user_id":"efe5aa1b-4239-4d62-a18f-4375084250eb","society_title":"chairman"}	Pass
TC-ROLE-008	treasurer (co_secretary) sets a title	ONLY_SECRETARY_CAN_SET_TITLE	400 {"code":"P0001","details":null,"hint":null,"message":"ONLY_SECRETARY_CAN_SET_TITLE"}	Pass
TC-DB-020	DB: titles map to roles	03 co_secretary/treasurer, 04 board_member/committee_member, 27 secretary/chairman	03:co_secretary/treasurer,04:board_member/committee_member,07:member/-,27:secretary/chairman	Pass
TC-DB-021	DB: treasurer/committee titles do not add authority rows	1	1	Pass
TC-ROLE-010	member adds a guard	refused	400 {"code":"P0001","details":null,"hint":null,"message":"NOT_SECRETARY"}	Pass
TC-ROLE-011	secretary of A adds guard to B	refused	400 {"code":"P0001","details":null,"hint":null,"message":"NOT_SECRETARY"}	Pass
TC-ROLE-012	claim_guard before being added	refused / not found	400 {"code":"P0001","details":null,"hint":null,"message":"NOT_A_GUARD"}	Pass
TC-ROLE-013	secretary adds guard 9000000006	200	200 {"name":"QA-T Guard Lotus","guard_id":"e769e142-a678-4c6e-8eae-8e055a6e61b4"}	Pass
TC-ROLE-014	guard claims	200	200 {"guard_id":"e769e142-a678-4c6e-8eae-8e055a6e61b4","society_id":"1b4973c3-50a7-4de5-837b-28c140be2ded","other_societies":0}	Pass
TC-DB-022	DB: guard row active and linked, no membership	active|t and 0 memberships	active|t / mem=0	Pass
TC-ROLE-015	guard JWT claims after refresh	role guard, guard_society_id = B, society_id null (guards have no society scope)	{"role":"guard","guard_society_id":"1b4973c3-50a7-4de5-837b-28c140be2ded","society_id":null}	Pass

ID	Title	Expected	Actual	Status
TC-ROLE-101	setup_get_state: role matrix	allowed only: chairman, treasurer, admin, sales	anon=401; admin=OK; chairman=OK; treasurer=OK; committee=NOT_SOCIETY_MANAGER; member=NOT_SOCIETY_MANAGER; guard=NOT_SOCIETY_MANAGER; A-secretary=NOT_SOCIETY_MANAGER; A-owner=NOT_SOCIETY_MANAGER; A-tenant=NOT_SOCIETY_MANAGER; A-family=NOT_SOCIETY_MANAGER	Pass
TC-ROLE-102	society_admin_dashboard: role matrix	allowed only: chairman, treasurer, admin, sales	anon=401; admin=OK; chairman=OK; treasurer=OK; committee=NOT_SOCIETY_MANAGER; member=NOT_SOCIETY_MANAGER; guard=NOT_SOCIETY_MANAGER; A-secretary=NOT_SOCIETY_MANAGER; A-owner=NOT_SOCIETY_MANAGER; A-tenant=NOT_SOCIETY_MANAGER; A-family=NOT_SOCIETY_MANAGER	Pass
TC-ROLE-103	resident_dashboard: role matrix	allowed only: chairman, treasurer, committee, member	anon=401; admin=NOT_A_MEMBER; chairman=OK; treasurer=OK; committee=OK; member=OK; guard=NOT_A_MEMBER; A-secretary=NOT_A_MEMBER; A-owner=NOT_A_MEMBER; A-tenant=NOT_A_MEMBER; A-family=NOT_A_MEMBER	Pass
TC-ROLE-104	security_dashboard: role matrix	allowed only: guard	anon=401; admin=NOT_A_GUARD; chairman=NOT_A_GUARD; treasurer=NOT_A_GUARD; committee=NOT_A_GUARD; member=NOT_A_GUARD; guard=OK; A-secretary=NOT_A_GUARD; A-owner=NOT_A_GUARD; A-tenant=NOT_A_GUARD; A-family=NOT_A_GUARD	Pass
TC-ROLE-105	guard_list_flats: role matrix	allowed only: guard	anon=401; admin=NOT_GUARD; chairman=NOT_GUARD; treasurer=NOT_GUARD; committee=NOT_GUARD; member=NOT_GUARD; guard=OK; A-secretary=NOT_GUARD; A-owner=NOT_GUARD; A-tenant=NOT_GUARD; A-family=NOT_GUARD	Pass
TC-ROLE-106	manager_list_resident_records: role matrix	allowed only: chairman, treasurer	anon=401; admin=NOT_SOCIETY_MANAGER; chairman=OK; treasurer=OK; committee=NOT_SOCIETY_MANAGER; member=NOT_SOCIETY_MANAGER; guard=NOT_SOCIETY_MANAGER; A-secretary=NOT_SOCIETY_MANAGER; A-owner=NOT_SOCIETY_MANAGER; A-tenant=NOT_SOCIETY_MANAGER; A-family=NOT_SOCIETY_MANAGER	Pass
TC-ROLE-107	manager_list_society_residents: role matrix	allowed only: chairman, treasurer	anon=401; admin=NOT_SOCIETY_MANAGER; chairman=OK; treasurer=OK; committee=NOT_SOCIETY_MANAGER; member=NOT_SOCIETY_MANAGER; guard=NOT_SOCIETY_MANAGER; A-secretary=NOT_SOCIETY_MANAGER; A-owner=NOT_SOCIETY_MANAGER; A-tenant=NOT_SOCIETY_MANAGER; A-family=NOT_SOCIETY_MANAGER	Pass
TC-ROLE-108	manager_resident_type_counts: role matrix	allowed only: chairman, treasurer	anon=401; admin=NOT_SOCIETY_MANAGER; chairman=OK; treasurer=OK; committee=NOT_SOCIETY_MANAGER; member=NOT_SOCIETY_MANAGER; guard=NOT_SOCIETY_MANAGER; A-secretary=NOT_SOCIETY_MANAGER; A-owner=NOT_SOCIETY_MANAGER; A-tenant=NOT_SOCIETY_MANAGER; A-family=NOT_SOCIETY_MANAGER	Pass
TC-ROLE-109	manager_list_staff: role matrix	allowed only: chairman, treasurer	anon=401; admin=NOT_SOCIETY_MANAGER; chairman=OK; treasurer=OK; committee=NOT_SOCIETY_MANAGER; member=NOT_SOCIETY_MANAGER; guard=NOT_SOCIETY_MANAGER; A-secretary=NOT_SOCIETY_MANAGER; A-owner=NOT_SOCIETY_MANAGER; A-tenant=NOT_SOCIETY_MANAGER; A-family=NOT_SOCIETY_MANAGER	Pass
TC-ROLE-110	manager_list_tenants: role matrix	allowed only: chairman, treasurer	anon=401; admin=NOT_SOCIETY_MANAGER; chairman=OK; treasurer=OK; committee=NOT_SOCIETY_MANAGER; member=NOT_SOCIETY_MANAGER; guard=NOT_SOCIETY_MANAGER; A-secretary=NOT_SOCIETY_MANAGER; A-owner=NOT_SOCIETY_MANAGER; A-tenant=NOT_SOCIETY_MANAGER; A-family=NOT_SOCIETY_MANAGER	Pass
TC-ROLE-111	import_list_batches: role matrix	allowed only: chairman, treasurer	anon=401; admin=NOT_SOCIETY_MANAGER; chairman=OK; treasurer=OK; committee=NOT_SOCIETY_MANAGER; member=NOT_SOCIETY_MANAGER; guard=NOT_SOCIETY_MANAGER; A-secretary=NOT_SOCIETY_MANAGER; A-owner=NOT_SOCIETY_MANAGER; A-tenant=NOT_SOCIETY_MANAGER; A-family=NOT_SOCIETY_MANAGER	Pass

ID	Title	Expected	Actual	Status
TC-ROLE-112	get_society_registration: role matrix	allowed only: chairman, treasurer, committee, member, admin, sales	anon=401; admin=OK; chairman=OK; treasurer=OK; committee=OK; member=OK; guard=NOT_A_MEMBER; A-secretary=NOT_A_MEMBER; A-owner=NOT_A_MEMBER; A-tenant=NOT_A_MEMBER; A-family=NOT_A_MEMBER	Pass
TC-ROLE-113	my_society_features: role matrix	allowed only: chairman, treasurer, committee, member, guard, admin, sales	anon=401; admin=OK; chairman=OK; treasurer=OK; committee=OK; member=OK; guard=OK; A-secretary=NOT_A_MEMBER; A-owner=NOT_A_MEMBER; A-tenant=NOT_A_MEMBER; A-family=NOT_A_MEMBER	Pass
TC-ROLE-114	family_invite_list: role matrix	allowed only: chairman, treasurer, committee, member	anon=401; admin=NOT_ALLOWED; chairman=empty; treasurer=empty; committee=empty; member=empty; guard=NOT_ALLOWED; A-secretary=NOT_ALLOWED; A-owner=NOT_ALLOWED; A-tenant=NOT_ALLOWED; A-family=NOT_ALLOWED	Pass
TC-ROLE-115	list_flat_owners: role matrix	allowed only: chairman, treasurer, member	anon=401; admin=NOT_ALLOWED; chairman=empty; treasurer=empty; committee=NOT_ALLOWED; member=empty; guard=NOT_ALLOWED; A-secretary=NOT_ALLOWED; A-owner=NOT_ALLOWED; A-tenant=NOT_ALLOWED; A-family=NOT_ALLOWED	Pass
TC-ROLE-116	reveal_phone: role matrix	allowed only: chairman, treasurer, committee, member	anon=401; admin=NO_SOCIETY; chairman=OK; treasurer=OK; committee=OK; member=OK; guard=NO_SOCIETY; A-secretary=NOT_FOUND_OR_CROSS_TENANT; A-owner=NOT_FOUND_OR_CROSS_TENANT; A-tenant=NOT_FOUND_OR_CROSS_TENANT; A-family=NOT_FOUND_OR_CROSS_TENANT	Pass
TC-ROLE-117	get_dashboard_summary: role matrix	allowed only: chairman, treasurer, committee, member, A-secretary, A-owner, A-tenant, A-family	anon=401; admin=NO_SOCIETY; chairman=OK; treasurer=OK; committee=OK; member=OK; guard=NO_SOCIETY; A-secretary=OK; A-owner=OK; A-tenant=OK; A-family=OK	Pass
TC-ROLE-118	admin_list_societies: role matrix	allowed only: admin, sales	anon=401; admin=OK; chairman=NOT_PLATFORM_STAFF; treasurer=NOT_PLATFORM_STAFF; committee=NOT_PLATFORM_STAFF; member=NOT_PLATFORM_STAFF; guard=NOT_PLATFORM_STAFF; A-secretary=NOT_PLATFORM_STAFF; A-owner=NOT_PLATFORM_STAFF; A-tenant=NOT_PLATFORM_STAFF; A-family=NOT_PLATFORM_STAFF	Pass
TC-ROLE-119	admin_stats: role matrix	allowed only: admin, sales	anon=401; admin=OK; chairman=NOT_PLATFORM_STAFF; treasurer=NOT_PLATFORM_STAFF; committee=NOT_PLATFORM_STAFF; member=NOT_PLATFORM_STAFF; guard=NOT_PLATFORM_STAFF; A-secretary=NOT_PLATFORM_STAFF; A-owner=NOT_PLATFORM_STAFF; A-tenant=NOT_PLATFORM_STAFF; A-family=NOT_PLATFORM_STAFF	Pass
TC-ROLE-120	admin_onboarding_metrics: role matrix	allowed only: admin, sales	anon=401; admin=OK; chairman=NOT_PLATFORM_STAFF; treasurer=NOT_PLATFORM_STAFF; committee=NOT_PLATFORM_STAFF; member=NOT_PLATFORM_STAFF; guard=NOT_PLATFORM_STAFF; A-secretary=NOT_PLATFORM_STAFF; A-owner=NOT_PLATFORM_STAFF; A-tenant=NOT_PLATFORM_STAFF; A-family=NOT_PLATFORM_STAFF	Pass
TC-ROLE-121	admin_society_detail: role matrix	allowed only: admin, sales	anon=401; admin=OK; chairman=NOT_PLATFORM_STAFF; treasurer=NOT_PLATFORM_STAFF; committee=NOT_PLATFORM_STAFF; member=NOT_PLATFORM_STAFF; guard=NOT_PLATFORM_STAFF; A-secretary=NOT_PLATFORM_STAFF; A-owner=NOT_PLATFORM_STAFF; A-tenant=NOT_PLATFORM_STAFF; A-family=NOT_PLATFORM_STAFF	Pass
TC-ROLE-122	admin_society_authorities: role matrix	allowed only: admin, sales	anon=401; admin=OK; chairman=NOT_PLATFORM_STAFF; treasurer=NOT_PLATFORM_STAFF; committee=NOT_PLATFORM_STAFF; member=NOT_PLATFORM_STAFF; guard=NOT_PLATFORM_STAFF; A-secretary=NOT_PLATFORM_STAFF; A-owner=NOT_PLATFORM_STAFF; A-tenant=NOT_PLATFORM_STAFF; A-family=NOT_PLATFORM_STAFF	Pass

ID	Title	Expected	Actual	Status
TC-ROLE-123	admin_society_history: role matrix	allowed only: admin, sales	anon=401; admin=OK; chairman=NOT_PLATFORM_STAFF; treasurer=NOT_PLATFORM_STAFF; committee=NOT_PLATFORM_STAFF; member=NOT_PLATFORM_STAFF; guard=NOT_PLATFORM_STAFF; A-secretary=NOT_PLATFORM_STAFF; A-owner=NOT_PLATFORM_STAFF; A-tenant=NOT_PLATFORM_STAFF; A-family=NOT_PLATFORM_STAFF	Pass
TC-ROLE-124	admin_list_connect_requests: role matrix	allowed only: admin, sales	anon=401; admin=OK; chairman=NOT_PLATFORM_STAFF; treasurer=NOT_PLATFORM_STAFF; committee=NOT_PLATFORM_STAFF; member=NOT_PLATFORM_STAFF; guard=NOT_PLATFORM_STAFF; A-secretary=NOT_PLATFORM_STAFF; A-owner=NOT_PLATFORM_STAFF; A-tenant=NOT_PLATFORM_STAFF; A-family=NOT_PLATFORM_STAFF	Pass
TC-ROLE-125	admin_list_platform_users: role matrix	allowed only: admin	anon=401; admin=empty; chairman=NOT_PLATFORM_ADMIN; treasurer=NOT_PLATFORM_ADMIN; committee=NOT_PLATFORM_ADMIN; member=NOT_PLATFORM_ADMIN; guard=NOT_PLATFORM_ADMIN; A-secretary=NOT_PLATFORM_ADMIN; A-owner=NOT_PLATFORM_ADMIN; A-tenant=NOT_PLATFORM_ADMIN; A-family=NOT_PLATFORM_ADMIN	Pass
TC-ROLE-126	admin_list_platform_audit: role matrix	allowed only: admin	anon=401; admin=empty; chairman=NOT_PLATFORM_ADMIN; treasurer=NOT_PLATFORM_ADMIN; committee=NOT_PLATFORM_ADMIN; member=NOT_PLATFORM_ADMIN; guard=NOT_PLATFORM_ADMIN; A-secretary=NOT_PLATFORM_ADMIN; A-owner=NOT_PLATFORM_ADMIN; A-tenant=NOT_PLATFORM_ADMIN; A-family=NOT_PLATFORM_ADMIN	Pass

6. Bugs found (roles)

ID	Severity	Title
API-001	High	A member can file a complaint attributed to any other flat in the society
API-002	Medium	Every resident can read every flat's visitor log, including visitor phone numbers
API-003	Low	A guard cannot resolve an SOS addressed to guards

Parisar: API and Database Testing

Area key: `roles`. Last updated: 2026-11-10 10:02 UTC. Test cases: 165. Passed: 162. Failed: 3. Blocked: 0. Not tested: 0.

1. API surface

There is no API server. Clients call PostgREST directly:

Kind	URL	Auth
RPC	`POST http://127.0.0.1:54321/rest/v1/rpc/<name>` with JSON named args	`apikey: <anon key>` and `Authorization: Bearer <user JWT>`
Table	`GET/POST/PATCH/DELETE /rest/v1/<table>`	same; row-level security decides
Auth	`POST /auth/v1/otp`, `POST /auth/v1/verify` (`type: sms`), `POST /auth/v1/token?grant_type=refresh_token`, `POST /auth/v1/logout`	anon key

Inventory (read from `pg_proc` on the running DB, 10 Nov 2026): 404 functions in `public`; 186 are executable by `authenticated` only; the only application functions executable by `anon` are `submit_connect_request` and `get_connect_request_status` (the other anon-executable ones are `btree_gist` extension internals). 27 are executable by neither (internal helpers, hooks). Full list: `docs/qa/scripts/api/rpcs.txt`.

Error convention (verified): a raised business error returns HTTP **400** with `{"code":"P0001","message":"<CODE>"}`; a returned error is HTTP **200** with `{"error":"<CODE>"}`; a missing grant returns **401** `42501 permission denied for function`. There are no 403/404/409 statuses: "not found" and "conflict/duplicate" are 400 or 200 with a code. Note: local Kong does not require the `apikey` header; a request with no key and no token runs as `anon` and is refused by grants (TC-API-001).

2. Harness

`docs/qa/scripts/api/lib.mjs` (Node 18+, plain `fetch`). Keys are read at runtime from `supabase status -o env`; none are stored. `login(phone)` does OTP `123456` sign-in and caches sessions in the scratchpad (GoTrue allows only 10 sign-ins per 5 minutes per IP, shared with other testers). `sql()` refuses anything but a single SELECT. Each `sNN_*.mjs` script is one workflow and appends to `results-roles.jsonl`; `gen.mjs` builds these documents. Run: `node s02_connect_register.mjs` from a copy of the folder.

3. Test cases

Authentication (no token / no key)

ID	Title	Expected	Actual	Status
TC-API-001	No apikey and no token: protected RPC	401 (request runs as anon and is refused)	401 {"code":"42501","details":null,"hint":null,"message":"permission denied for function admin_list_connect_requests"}	Pass
TC-API-001b	No apikey and no token: table read society_memberships	401 or empty	200 []	Pass

Connect request and admin request actions, register society

ID	Title	Expected	Actual	Status
TC-API-002	submit: society name 1 char	INVALID_SOCIETY_NAME	400 {"code":"P0001","details":null,"hint":null,"message":"INVALID_SOCIETY_NAME"}	Pass
TC-API-003	submit: bad phone	INVALID_PHONE	400 {"code":"P0001","details":null,"hint":null,"message":"INVALID_PHONE"}	Pass
TC-API-004	submit: no slot and not call-now	SLOT_REQUIRED	400 {"code":"P0001","details":null,"hint":null,"message":"SLOT_REQUIRED"}	Pass
TC-API-005	submit: slot in past	SLOT_IN_PAST	400 {"code":"P0001","details":null,"hint":null,"message":"SLOT_IN_PAST"}	Pass
TC-API-006	submit: bad email	INVALID_EMAIL	400 {"code":"P0001","details":null,"hint":null,"message":"INVALID_EMAIL"}	Pass
TC-API-007	submit: valid request (anon)	200 with request_code, status call_scheduled	200 {"status":"call_scheduled","call_now":false,"created_at":"2026-11-10T09:17:19.229927+00:00","alternate_at":null,"preferred_at":"2026-11-12T09:17:17.632+00:00","request_code":"PR-DF64-PC9E","scheduled_at":"2026-11-12T09:1...	Pass
TC-API-008	submit: response does not expose id/phone	only public fields	["status","call_now","created_at","alternate_at","preferred_at","request_code","scheduled_at","preferred_slot"]	Pass
TC-API-009	submit: duplicate open request same phone (other format)	{error: REQUEST_ALREADY_OPEN}	200 {"error":"REQUEST_ALREADY_OPEN"}	Pass
TC-DB-001	DB: exactly one open request for phone	1	1	Pass
TC-DB-002	DB: duplicate authority number of contact dropped	1 entry	[{"name": "QA-T Chairman Lotus", "phone": "9000000027"}]	Pass
TC-API-010	status lookup with code+phone	200 status call_scheduled	200 {"status":"call_scheduled","call_now":false,"created_at":"2026-11-10T09:17:19.229927+00:00","alternate_at":null,"preferred_at":"2026-11-12T09:17:17.632+00:00","request_code":"PR-DF64-PC9E","scheduled_at":"2026-11-12T09:1...	Pass
TC-API-011	status lookup with wrong phone	REQUEST_NOT_FOUND	200 {"error":"REQUEST_NOT_FOUND"}	Pass
TC-API-012	anon direct select on society_enrollment_requests	no rows / 401	401 {"code":"42501","details":null,"hint":null,"message":"permission denied for table society_enrollment_requests"}	Pass
TC-API-013	admin_list_connect_requests as plain user	NOT_PLATFORM_STAFF	400 {"code":"P0001","details":null,"hint":null,"message":"NOT_PLATFORM_STAFF"}	Pass
TC-API-014	admin_list_connect_requests as anon	401/permission denied	401 {"code":"42501","details":null,"hint":null,"message":"permission denied for function admin_list_connect_requests"}	Pass
TC-API-015	admin list search by request code	1 item	200 {"items":[{"id":"d69ad157-caae-4efc-97f6-85c0fe1091ff","email":"qa-t-lotus@example.com","phone":"+919000000027","status":"call_scheduled","message":"QA-T roles test","call_now":false,"called_at":null,"created_at":"2026-1...	Pass

ID	Title	Expected	Actual	Status
TC-API-016	admin list invalid status filter	INVALID_STATUS	400 {"code":"P0001","details":null,"hint":null,"message":"INVALID_STATUS"}	Pass
TC-API-017	admin get unknown id	REQUEST_NOT_FOUND	400 {"code":"P0001","details":null,"hint":null,"message":"REQUEST_NOT_FOUND"}	Pass
TC-API-018	admin reschedule	200 status rescheduled	200 {"id":"d69ad157-caae-4efc-97f6-85c0fe1091ff","email":"qa-t-lotus@example.com","phone":"+919000000027","status":"rescheduled","message":"QA-T roles test","call_now":false,"called_at":null,"created_at":"2026-11-10T09:17:19...	Pass
TC-API-019	admin reschedule into past	SLOT_IN_PAST	400 {"code":"P0001","details":null,"hint":null,"message":"SLOT_IN_PAST"}	Pass
TC-API-020	admin mark called	200 status contacted	200 {"id":"d69ad157-caae-4efc-97f6-85c0fe1091ff","email":"qa-t-lotus@example.com","phone":"+919000000027","status":"contacted","message":"QA-T roles test","call_now":false,"called_at":"2026-11-10T09:17:19.902497+00:00","crea...	Pass
TC-API-021	admin reject with 1-char reason	INVALID_REASON	400 {"code":"P0001","details":null,"hint":null,"message":"INVALID_REASON"}	Pass
TC-API-022	admin get shows history	submitted, rescheduled, called	["connect.submitted","connect.rescheduled","connect.called"]	Pass
TC-API-023	admin_register_society as non-staff	NOT_PLATFORM_STAFF	400 {"code":"P0001","details":null,"hint":null,"message":"NOT_PLATFORM_STAFF"}	Pass
TC-API-024	register: pincode starting 0	INVALID_PINCODE	400 {"code":"P0001","details":null,"hint":null,"message":"INVALID_PINCODE"}	Pass
TC-API-025	register: feature without module	UNKNOWN_FEATURE	400 {"code":"P0001","details":null,"hint":null,"message":"UNKNOWN_FEATURE"}	Pass
TC-DB-003	DB: failed registrations created no society (atomic)	0	0	Pass
TC-API-026	register society from request	200 society_id, code, authority_count 1	200 {"code":"2KRN-DFHB","features":["bookings","polls","directory","flat_actions","community","moderation","visitors","staff_directory","facility_calendar"],"request_id":"d69ad157-caae-4efc-97f6-85c0fe1091ff","society_id":"1...	Pass
TC-API-027	register again from the same request	REQUEST_ALREADY_REGISTERED (or duplicate reg no.)	400 {"code":"P0001","details":null,"hint":null,"message":"DUPLICATE_REGISTRATION_NUMBER"}	Pass
TC-DB-004	DB: request registered and linked	registered|	registered|1b4973c3-50a7-4de5-837b-28c140be2ded	Pass
TC-DB-005	DB: authority row seeded from request contact	1|9000000027	1|9000000027	Pass
TC-API-027b	register again from same request, new reg number	REQUEST_ALREADY_REGISTERED, no 2nd society	400 {"code":"P0001","details":null,"hint":null,"message":"REQUEST_ALREADY_REGISTERED"}	Pass

Authority login and claim

ID	Title	Expected	Actual	Status
TC-API-030	my_authority_societies for new authority	1 society, claimed false, needs_setup	200 {"societies":[{"claimed":false,"has_flat":false,"membership":null,"society_id":"1b4973c3-50a7-4de5-837b-28c140be2ded","setup_state":"needs_setup","authority_id":"e8336d5d-574d-4de7-afcf-d81f2733079d","society_code":"2KRN...	Pass
TC-API-031	my_authority_societies for non-authority	empty list	200 {"societies":[]}	Pass
TC-API-032	claim_authority_for_society by non-authority	NOT_AN_AUTHORITY	400 {"code":"P0001","details":null,"hint":null,"message":"NOT_AN_AUTHORITY"}	Pass
TC-API-033	claim_authority_for_society by authority	200 refresh_required true	200 {"society_id":"1b4973c3-50a7-4de5-837b-28c140be2ded","setup_state":"needs_setup","refresh_required":true}	Pass
TC-API-034	claim again (idempotent)	200, still one membership	200 {"society_id":"1b4973c3-50a7-4de5-837b-28c140be2ded","setup_state":"needs_setup","refresh_required":true}	Pass
TC-DB-010	DB: one secretary membership after 2 claims	1|secretary/active	1|secretary/active	Pass
TC-API-035	JWT after refresh carries society_id + role	society_id=1b4973c3-50a7-4de5-837b-28c140be2ded, role=secretary	{"s":"1b4973c3-50a7-4de5-837b-28c140be2ded","r":"secretary"}	Pass

Authority claim and setup

ID	Title	Expected	Actual	Status
TC-API-036	setup_upsert_wing on society B by secretary of society A	NOT_SOCIETY_MANAGER	400 {"code":"P0001","details":null,"hint":null,"message":"NOT_SOCIETY_MANAGER"}	Pass
TC-API-037	setup_upsert_wing by non-member	NOT_SOCIETY_MANAGER	400 {"code":"P0001","details":null,"hint":null,"message":"NOT_SOCIETY_MANAGER"}	Pass
TC-API-038	setup_get_state as anon	401	401 {"code":"42501","details":null,"hint":null,"message":"permission denied for function setup_get_state"}	Pass
TC-API-039	setup_upsert_wing empty name	INVALID_WING_NAME	400 {"code":"P0001","details":null,"hint":null,"message":"INVALID_WING_NAME"}	Pass
TC-API-040	setup_upsert_wing create	200 Wing code A	200 {"id":"2f519ebe-3316-4895-b6c6-a621d5ffed77","code":"A","name":"QA-T Wing A","society_id":"1b4973c3-50a7-4de5-837b-28c140be2ded"}	Pass
TC-API-041	setup_upsert_wing duplicate name (case-insensitive)	WING_NAME_EXISTS	400 {"code":"P0001","details":null,"hint":null,"message":"WING_NAME_EXISTS"}	Pass

ID	Title	Expected	Actual	Status
TC-API-042	setup_upsert_wing duplicate code	WING_CODE_EXISTS	400 {"code":"P0001","details":null,"hint":null,"message":"WING_CODE_EXISTS"}	Pass
TC-API-043	setup_upsert_floor number 999	INVALID_FLOOR_NUMBER	400 {"code":"P0001","details":null,"hint":null,"message":"INVALID_FLOOR_NUMBER"}	Pass
TC-API-044	setup_upsert_floor duplicate number in wing	FLOOR_EXISTS	400 {"code":"P0001","details":null,"hint":null,"message":"FLOOR_EXISTS"}	Pass
TC-API-045	setup_complete with no flats	SETUP_NEEDS_FLAT	400 {"code":"P0001","details":null,"hint":null,"message":"SETUP_NEEDS_FLAT"}	Pass
TC-API-046	bulk flats with duplicate in list	FLAT_EXISTS: 101, nothing created	400 {"code":"P0001","details":null,"hint":null,"message":"FLAT_EXISTS: 101"}	Pass
TC-DB-011	DB: bulk create is all-or-nothing	0 flats	0	Pass
TC-API-047	bulk flats valid	created 2	200 {"flats":[{"id":"2f3d4cb5-0b5e-49d2-8229-043079236ffa","number":"101","status":"vacant","wing_id":"2f519ebe-3316-4895-b6c6-a621d5ffed77","bedrooms":null,"floor_id":"d09e509d-7e18-465f-8b37-d27a001580f3","area_sqft":null,...	Pass
TC-API-048	same flat number 101 in another wing	allowed (unique per wing)	200 {"flats":[{"id":"b0ff90c8-9a54-43ae-8d7e-5a10e3fd02dc","number":"101","status":"vacant","wing_id":"27424f91-1ac0-4439-b256-3c35859fc535","bedrooms":null,"floor_id":"9e2c8269-37c0-441e-b447-a80854bcab5a","area_sqft":null,...	Pass
TC-API-049	setup_upsert_flat duplicate number	FLAT_EXISTS	400 {"code":"P0001","details":null,"hint":null,"message":"FLAT_EXISTS"}	Pass
TC-API-050	setup_upsert_flat floor of another wing	FLOOR_NOT_FOUND	400 {"code":"P0001","details":null,"hint":null,"message":"FLOOR_NOT_FOUND"}	Pass
TC-API-051	skip a required step	STEP_NOT_SKIPPABLE	400 {"code":"P0001","details":null,"hint":null,"message":"STEP_NOT_SKIPPABLE"}	Pass
TC-API-052	setup_complete	200 counts wings 2 floors 3 flats 5	200 {"counts":{"flats":5,"wings":2,"floors":3},"society_id":"1b4973c3-50a7-4de5-837b-28c140be2ded","setup_state":"needs_personal_onboarding","setup_completed_at":"2026-11-10T09:18:57.072361+00:00"}	Pass

Resident onboarding (onboard_resident)

ID	Title	Expected	Actual	Status
TC-API-053	authority onboards own flat	status active	200 {"status":"active","society_id":"1b4973c3-50a7-4de5-837b-28c140be2ded"}	Pass
TC-DB-012	DB: authority still one membership, now with flat	1|secretary/active/true	1|secretary/active/true	Pass
TC-API-054-03	resident 9000000003 onboards A-102 as owner	status active	200 {"status":"active","society_id":"1b4973c3-50a7-4de5-837b-28c140be2ded"}	Pass

ID	Title	Expected	Actual	Status
TC-API-054-04	resident 9000000004 onboards A-201 as owner	status active	200 {"status":"active","society_id":"1b4973c3-50a7-4de5-837b-28c140be2ded"}	Pass
TC-API-054-07	resident 9000000007 onboards A-202 as owner	status active	200 {"status":"active","society_id":"1b4973c3-50a7-4de5-837b-28c140be2ded"}	Pass
TC-API-055	onboard with wrong society code	{error: INVALID_CODE}	200 {"error":"INVALID_CODE"}	Pass
TC-API-056	onboard with flat not in society	{error: FLAT_NOT_IN_SOCIETY}	200 {"error":"FLAT_NOT_IN_SOCIETY"}	Pass

Part 16: multi-society isolation

ID	Title	Expected	Actual	Status
TC-ISO-301	chairman: read every society-scoped table (49) filtered to the other society	0 rows from every table	0 rows from all 49 tables	Pass
TC-ISO-302	treasurer: read every society-scoped table (49) filtered to the other society	0 rows from every table	0 rows from all 49 tables	Pass
TC-ISO-303	committee: read every society-scoped table (49) filtered to the other society	0 rows from every table	0 rows from all 49 tables	Pass
TC-ISO-304	member: read every society-scoped table (49) filtered to the other society	0 rows from every table	0 rows from all 49 tables	Pass
TC-ISO-305	guard: read every society-scoped table (49) filtered to the other society	0 rows from every table	0 rows from all 49 tables	Pass
TC-ISO-306	A-secretary: read every society-scoped table (49) filtered to the other society	0 rows from every table	0 rows from all 49 tables	Pass
TC-ISO-307	A-owner: read every society-scoped table (49) filtered to the other society	0 rows from every table	0 rows from all 49 tables	Pass
TC-ISO-308	A-tenant: read every society-scoped table (49) filtered to the other society	0 rows from every table	0 rows from all 49 tables	Pass
TC-ISO-309	A-family: read every society-scoped table (49) filtered to the other society	0 rows from every table	0 rows from all 49 tables	Pass
TC-ISO-310	secretary of B calls setup_get_state with society A ids	refused, no A data	400 {"code":"P0001","details":null,"hint":null,"message":"NOT_SOCIETY_MANAGER"}	Pass
TC-ISO-311	secretary of B calls society_admin_dashboard with society A ids	refused, no A data	400 {"code":"P0001","details":null,"hint":null,"message":"NOT_SOCIETY_MANAGER"}	Pass
TC-ISO-312	secretary of B calls resident_dashboard with society A ids	refused, no A data	400 {"code":"P0001","details":null,"hint":null,"message":"NOT_A_MEMBER"}	Pass

ID	Title	Expected	Actual	Status
TC-ISO-313	secretary of B calls manager_list_resident_records with society A ids	refused, no A data	400 {"code":"P0001","details":null,"hint":null,"message":"NOT_SOCIETY_MANAGER"}	Pass
TC-ISO-314	secretary of B calls manager_list_staff with society A ids	refused, no A data	400 {"code":"P0001","details":null,"hint":null,"message":"NOT_SOCIETY_MANAGER"}	Pass
TC-ISO-315	secretary of B calls manager_list_tenants with society A ids	refused, no A data	400 {"code":"P0001","details":null,"hint":null,"message":"NOT_SOCIETY_MANAGER"}	Pass
TC-ISO-316	secretary of B calls import_list_batches with society A ids	refused, no A data	400 {"code":"P0001","details":null,"hint":null,"message":"NOT_SOCIETY_MANAGER"}	Pass
TC-ISO-317	secretary of B calls get_society_registration with society A ids	refused, no A data	400 {"code":"P0001","details":null,"hint":null,"message":"NOT_A_MEMBER"}	Pass
TC-ISO-318	secretary of B calls my_society_features with society A ids	refused, no A data	400 {"code":"P0001","details":null,"hint":null,"message":"NOT_A_MEMBER"}	Pass
TC-ISO-319	secretary of B calls list_flat_owners with society A ids	refused, no A data	400 {"code":"P0001","details":null,"hint":null,"message":"NOT_ALLOWED"}	Pass
TC-ISO-320	secretary of B calls reveal_phone with society A ids	refused, no A data	400 {"code":"P0001","details":null,"hint":null,"message":"NOT_FOUND_OR_CROSS_TENANT"}	Pass
TC-ISO-321	secretary of B calls set_active_society with society A ids	refused, no A data	400 {"code":"P0001","details":null,"hint":null,"message":"NOT_A_MEMBER"}	Pass
TC-ISO-322	secretary of B calls family_invite_list with society A ids	refused, no A data	400 {"code":"P0001","details":null,"hint":null,"message":"NOT_ALLOWED"}	Pass
TC-ISO-323	secretary of B calls manager_resident_type_counts with society A ids	refused, no A data	400 {"code":"P0001","details":null,"hint":null,"message":"NOT_SOCIETY_MANAGER"}	Pass
TC-ISO-324	secretary of B calls add_complaint_response with society A ids	refused, no A data	400 {"code":"22P02","details":null,"hint":null,"message":"invalid input value for enum complaint_status: \"in_progress\""}	Pass
TC-ISO-325	secretary of A calls society_admin_dashboard on society B	refused	400 {"code":"P0001","details":null,"hint":null,"message":"NOT_SOCIETY_MANAGER"}	Pass
TC-ISO-326	secretary of A calls manager_list_resident_records on society B	refused	400 {"code":"P0001","details":null,"hint":null,"message":"NOT_SOCIETY_MANAGER"}	Pass
TC-ISO-327	secretary of A calls setup_get_state on society B	refused	400 {"code":"P0001","details":null,"hint":null,"message":"NOT_SOCIETY_MANAGER"}	Pass
TC-ISO-328	member PATCHes own society_memberships.role to secretary	denied, role unchanged	403 {"code":"42501","details":null,"hint":null,"message":"permission denied for table society_memberships"} / role=member	Pass
TC-ISO-329	member INSERTs itself into platform_admins	denied	403 {"code":"42501","details":null,"hint":null,"message":"permission denied for table platform_admins"}	Pass

ID	Title	Expected	Actual	Status
TC-ISO-330	member PATCHes societies.name	denied	403 {"code":"42501","details":null,"hint":null,"message":"permission denied for table societies"}	Pass
TC-ISO-331	member INSERTs society_features row (has table grant)	denied by RLS	403 {"code":"42501","details":null,"hint":null,"message":"new row violates row-level security policy for table \"society_features\""}	Pass
TC-ISO-332	member PATCHes platform_features price (has column grant)	0 rows changed	200 []	Pass
TC-ISO-333	member INSERTs itself as a guard	denied	403 {"code":"42501","details":null,"hint":null,"message":"permission denied for table society_guards"}	Pass
TC-ISO-334	member PATCHes profiles.active_society_id to society A	denied (no column grant)	403 {"code":"42501","details":null,"hint":null,"message":"permission denied for table profiles"}	Pass
TC-ISO-335	member set_active_society to a society it is not in	refused	400 {"code":"P0001","details":null,"hint":null,"message":"NOT_A_MEMBER"}	Pass
TC-ISO-336	member JWT after those attempts	society_id=B, role=member	{"s":"1b4973c3-50a7-4de5-837b-28c140be2ded","r":"member"}	Pass
TC-ISO-337	member reads profiles.phone directly	phone column not readable	403 {"code":"42501","details":null,"hint":null,"message":"permission denied for table profiles"}	Pass
TC-ISO-338	member lists profiles: none belong to society A	0	4 profiles visible, 0 in A	Pass

Complaints

ID	Title	Expected	Actual	Status
TC-API-401	guard files a complaint	refused (no membership)	400 {"code":"P0001","details":null,"hint":null,"message":"NO_SOCIETY"}	Pass
TC-API-402	member files complaint for someone else's flat	INVALID_FLAT	200 {"society_id":"1b4973c3-50a7-4de5-837b-28c140be2ded","complaint_id":"fc45ddee-2899-4ced-8331-c588c82867a0"}	Fail
TC-API-403	member files complaint (own flat)	200	200 {"society_id":"1b4973c3-50a7-4de5-837b-28c140be2ded","complaint_id":"0acccba5-3253-487c-a274-252e0dd00482"}	Pass
TC-API-404	re-submit with same complaint id (idempotency)	still 1 row	409 {"code":"23505","details":"Key (id)=(0acccba5-3253-487c-a274-252e0dd00482) already exists.","hint":n / rows=1	Pass
TC-API-405	member responds to a complaint	refused (board only)	400 {"code":"P0001","details":null,"hint":null,"message":"NOT_OWNER"}	Pass
TC-API-406	secretary of A responds to B complaint	refused	400 {"code":"P0001","details":null,"hint":null,"message":"NOT_OWNER"}	Pass

ID	Title	Expected	Actual	Status
TC-API-407	secretary of A reads B complaint directly	0 rows	200 []	Pass
TC-API-408	guard reads complaints table	0 rows	200 []	Pass
TC-API-409	committee member claims complaint	200	200 {"id":"0acccba5-3253-487c-a274-252e0dd00482","kind":"society","status":"checking","owner_id":"e6f23b21-acfe-4c4f-abba-d7366b6b1cc7","claimed_at":"2026-11-10T09:52:00.783998+00:00","created_at":"2026-11-10T09:51:58.605303...	Pass
TC-API-410	response kind 'open'	INVALID_RESPONSE_KIND	400 {"code":"P0001","details":null,"hint":null,"message":"INVALID_RESPONSE_KIND"}	Pass
TC-API-411	treasurer resolves a complaint owned by committee member	observed	400 {"code":"P0001","details":null,"hint":null,"message":"NOT_OWNER"}	Pass
TC-API-412	owner (committee) resolves	status resolved	200 / status=resolved	Pass
TC-DB-401	DB: complaint_responses rows for the trail	>=2	2	Pass
TC-API-413	respond to unknown complaint id	not found code	400 {"code":"P0001","details":null,"hint":null,"message":"NOT_OWNER"}	Pass

Notices

ID	Title	Expected	Actual	Status
TC-API-414	member posts a notice	INSUFFICIENT_ROLE	400 {"code":"P0001","details":null,"hint":null,"message":"INSUFFICIENT_ROLE"}	Pass
TC-API-415	guard posts a notice	refused	400 {"code":"P0001","details":null,"hint":null,"message":"NO_SOCIETY"}	Pass
TC-API-416	committee member posts a notice	200	200 {"poll_id":null,"society_id":"1b4973c3-50a7-4de5-837b-28c140be2ded","notification_id":"369688e2-247a-4389-8690-ec02aa9d47cb"}	Pass
TC-API-417	member of B reads the notice	1 row	200 [{"id":"369688e2-247a-4389-8690-ec02aa9d47cb","title":"QA-T Water cut Sunday"}]	Pass
TC-API-418	owner of A reads B notice	0 rows	200 []	Pass
TC-API-419	member DELETEs the notice directly (table has DELETE grant)	row kept	200 / rows=1	Pass

Polls

ID	Title	Expected	Actual	Status
TC-API-420	poll with one option	POLL_OPTIONS_RANGE	400 {"code":"P0001","details":null,"hint":null,"message":"POLL_OPTIONS_RANGE"}	Pass
TC-API-421	treasurer creates poll	200	200 {"poll_id":"13c0b8d3-3f8a-41cf-9b49-0686016bced7","society_id":"1b4973c3-50a7-4de5-837b-28c140be2ded","notification_id":"a646a55c-4fcd-4763-9165-a5b6f9a4528d"}	Pass
TC-API-422	member votes	200	200 {"tally":{"5841ed0c-470d-436a-bb5d-2d03df4898a3":1},"poll_id":"13c0b8d3-3f8a-41cf-9b49-0686016bced7","my_option":"5841ed0c-470d-436a-bb5d-2d03df4898a3"}	Pass
TC-API-423	member votes again (change vote)	still 1 vote row	200 / rows=1	Pass
TC-API-424	owner of A votes in B poll	POLL_NOT_FOUND	400 {"code":"P0001","details":null,"hint":null,"message":"POLL_NOT_FOUND"}	Pass
TC-API-425	guard votes	refused	400 {"code":"P0001","details":null,"hint":null,"message":"NO_SOCIETY"}	Pass
TC-API-426	member closes poll	INSUFFICIENT_ROLE	400 {"code":"P0001","details":null,"hint":null,"message":"INSUFFICIENT_ROLE"}	Pass
TC-API-427	member reads results	200	200 {"tally":{"8d816831-5144-4690-8aa1-1a600b470d46":1},"total":1,"poll_id":"13c0b8d3-3f8a-41cf-9b49-0686016bced7","my_option":"8d816831-5144-4690-8aa1-1a600b470d46"}	Pass
TC-API-428	treasurer closes poll	200	200 {"status":"closed","poll_id":"13c0b8d3-3f8a-41cf-9b49-0686016bced7"}	Pass
TC-API-429	vote after close	POLL_CLOSED	400 {"code":"P0001","details":null,"hint":null,"message":"POLL_CLOSED"}	Pass

Bookings

ID	Title	Expected	Actual	Status
TC-API-430	member creates an amenity	refused	400 {"code":"P0001","details":null,"hint":null,"message":"NOT_SECRETARY"}	Pass
TC-API-431	chairman creates an amenity	200	200 {"id":"9c468816-44c8-491f-b61c-587f1e02bdf8","name":"QA-T Clubhouse","status":"working","closed_until":null}	Pass
TC-API-432	end before start	TIME_ORDER	400 {"code":"P0001","details":null,"hint":null,"message":"TIME_ORDER"}	Pass
TC-API-433	5-hour booking	DURATION	400 {"code":"P0001","details":null,"hint":null,"message":"DURATION"}	Pass
TC-API-434	guard books	refused	400 {"code":"P0001","details":null,"hint":null,"message":"NO_SOCIETY"}	Pass

ID	Title	Expected	Actual	Status
TC-API-435	member books 10-11	200 pending	200 {"booking_id":"4a999d18-8974-4b96-b3c5-69e8222bc3f2","society_id":"1b4973c3-50a7-4de5-837b-28c140be2ded"}	Pass
TC-API-436	second request same slot while first pending	allowed as pending, or conflict code (observed)	200 {"booking_id":"17ffcb74-3833-4d12-b9c7-a19d75ec84b0","society_id":"1b4973c3-50a7-4de5-837b-28c140be2ded"}	Pass
TC-API-437	member approves own booking	INSUFFICIENT_ROLE	400 {"code":"P0001","details":null,"hint":null,"message":"INSUFFICIENT_ROLE"}	Pass
TC-API-438	secretary of A approves B booking	refused	400 {"code":"P0001","details":null,"hint":null,"message":"BOOKING_NOT_FOUND"}	Pass
TC-API-439	committee member approves	200	200 {"booking":{"id":"4a999d18-8974-4b96-b3c5-69e8222bc3f2","status":"approved","purpose":"QA-T birthday","amenity_id":"9c468816-44c8-491f-b61c-587f1e02bdf8","created_at":"2026-11-10T09:53:06.678251+00:00","society_id":"1b49...	Pass
TC-API-440	approve overlapping booking	not approved (slot_taken)	200 {"reason":"slot_taken","approved":false}	Pass
TC-DB-402	DB: at most one approved booking for the slot	1	1	Pass

Visitors

ID	Title	Expected	Actual	Status
TC-API-441	guard of B logs visit to a flat in A	FLAT_NOT_IN_SOCIETY	400 {"code":"P0001","details":null,"hint":null,"message":"FLAT_NOT_IN_SOCIETY"}	Pass
TC-API-442	member logs a visit (guard RPC)	NOT_GUARD	400 {"code":"P0001","details":null,"hint":null,"message":"NOT_GUARD"}	Pass
TC-API-443	guard logs visit to A-202	200	200 {"status":"pending","request_id":"8eed21c9-3c97-4eef-9f90-b26ac097e2cc"}	Pass
TC-API-444	resident of another flat decides	NOT_YOUR_FLAT	400 {"code":"P0001","details":null,"hint":null,"message":"NOT_YOUR_FLAT"}	Pass
TC-API-445	treasurer (manager) reads the visit	observed (secretary read policy)	200 [{"id":"8eed21c9-3c97-4eef-9f90-b26ac097e2cc","visitor_phone":"9876543210"}]	Pass
TC-API-446	committee member of another flat reads the visit	0 rows	200 [{"id":"8eed21c9-3c97-4eef-9f90-b26ac097e2cc"}]	Fail
TC-API-447	flat resident approves	200	200 {"status":"approved","request_id":"8eed21c9-3c97-4eef-9f90-b26ac097e2cc"}	Pass

ID	Title	Expected	Actual	Status
TC-API-448	decide again	ALREADY_DECIDED	400 {"code":"P0001","details":null,"hint":null,"message":"ALREADY_DECIDED"}	Pass
TC-API-449	resident PATCHes visitor_requests.status directly (table has UPDATE grant)	unchanged approved	200 / status=approved	Pass
TC-API-460	plain member (A-202) reads a visit for flat A-201	0 rows (not my flat)	200 [{"id":"bf6ff4ea-5021-4f3a-87f5-161ab58759d1","visitor_name":"QA-T Plumber visit","visitor_phone":"9876500000","flat_id":"68fc375f-e557-498c-9fd7-35ba46c2ba32"}]	Fail

SOS

ID	Title	Expected	Actual	Status
TC-API-450	owner of A raises SOS in B	NOT_A_MEMBER	400 {"code":"P0001","details":null,"hint":null,"message":"NOT_A_MEMBER"}	Pass
TC-API-451	SOS with empty description	INVALID_DESC	400 {"code":"P0001","details":null,"hint":null,"message":"INVALID_DESC"}	Pass
TC-API-452	member raises SOS to watchman	200	200 {"id":"7ea99031-50e7-4e62-9164-dcf48e235116"}	Pass
TC-API-453	guard dashboard shows active SOS	active_sos >= 1	200 {"denied":0,"pending":0,"approved":1,"active_sos":1,"society_id":"1b4973c3-50a7-4de5-837b-28c140be2ded","society_name":"QA-T Lotus Society","todays_visitors":1}	Pass
TC-API-454	secretary of A reads B SOS	0 rows	200 []	Pass
TC-API-455	committee member (not raiser) resolves	NOT_ALLOWED	400 {"code":"P0001","details":null,"hint":null,"message":"NOT_ALLOWED"}	Pass
TC-API-456	secretary of A resolves B SOS	refused	400 {"code":"P0001","details":null,"hint":null,"message":"NOT_ALLOWED"}	Pass
TC-API-457	guard resolves	observed	400 {"code":"P0001","details":null,"hint":null,"message":"NOT_ALLOWED"}	Pass
TC-API-458	treasurer (manager) resolves	resolved	204 null / resolved=t	Pass

4. Bugs found (API)

ID	Severity	Title
API-001	High	A member can file a complaint attributed to any other flat in the society
API-002	Medium	Every resident can read every flat's visitor log, including visitor phone numbers
API-003	Low	A guard cannot resolve an SOS addressed to guards

Parisar Security Testing (area: secperf)

Date: 10 November 2026. Tester: security-perf agent. Environment: local only. Web `next dev` at http://localhost:3000 (DEV mode, `ENABLE_DEV_ROUTES=1`), Supabase local at http://127.0.0.1:54321, Postgres container `supabase_db_parisar`. Branch `feat/saas-onboarding`.

Authorisation: the owner authorised this testing of their own local environment. Only safe, non-destructive techniques were used. No application code, migrations or config were changed. Write tests against the DB were done only inside `begin; ... rollback;`.

Accounts used: 9000000009 (own number, no membership = "outsider"), 9000000017 (owner, QA Sunrise Heights, read only), 9000000019 (tenant, read only). Sessions were obtained with `POST /auth/v1/otp` + `POST /auth/v1/verify` (dev OTP 123456). No PIN was set or changed on any account.

Evidence: raw command output is in `docs/qa/evidence/secperf/`. Keys and tokens were never printed.

Status legend: Pass, Fail (finding raised), Blocked, Not Tested.

Summary of findings

ID	Severity	Title
SEC-001	High	Dev server listens on all interfaces with `/dev-login` on; anyone on the LAN/ZeroTier can sign in as any test number, including platform admin 9000000030. Postgres (54322) and Supabase API (54321) also bound to 0.0.0.0
SEC-002	Critical (release blocker)	Dev backdoors still present: `test_otp` 123456 for 30 numbers, `dev_send_sms` hook that shows OTPs on screen, DevOtpHint, `/dev-login`, `/dev-preview`, dev PIN pepper fallback. Gated by NODE_ENV today; must be removed before any deploy
SEC-003	Medium	PIN is not enforced server-side: an OTP-only session of a user who has a PIN (`pin_set = true`) has full API access
SEC-004	Medium	Legacy PIN credential `pk1.<phone>.<pin>` is computable by anyone; legacy fallback is on by default, so non-upgraded accounts can be brute-forced directly against GoTrue's password grant, bypassing the app's PIN lockout
SEC-005	Low	PIN per-IP throttle uses the client-supplied `X-Forwarded-For` (forgeable); per-phone lock still applies
SEC-006	Low	`anon` role holds table privileges (SELECT, and on many tables INSERT/UPDATE/DELETE) on 33 public tables; only RLS stands in the way
SEC-007	Low	Auth cookie is not HttpOnly, lives 400 days, and the CSP allows `'unsafe-inline'` scripts, so any XSS would steal the session
SEC-008	Low	Middleware treats any path ending in `.<ext>` as public (`STATIC_FILE_RE`); protected pages still redirect at layout level, so nothing leaked, but the guard depends on every layout re-checking
SEC-009	Low	`society_accepts_joins(uuid)` (SECURITY DEFINER, no auth check) tells any signed-in user whether a society id exists and is not blocked

Details follow per test case. Further sections are appended as testing continues.

1. Authentication

SEC-TC-01 OTP login for a test number works without SMS

- Preconditions: number listed in `supabase/config.toml [auth.sms.test_otp]`.
- Steps: `POST /auth/v1/otp {"phone":"+919000000017"}`, then `POST /auth/v1/verify {"type":"sms","phone":...,"token":"123456"}`.
- Expected (dev): 200 and a session. Expected (prod): this must be impossible.
- Actual: otp 200, verify 200, access token + refresh token returned for 9000000009, 9000000017, 9000000019.

- Status: Pass (dev behaviour confirmed) — raises SEC-002 for production.
- Evidence: `docs/qa/evidence/secperf/auth-login.txt`

SEC-TC-02 PIN enforced on the API for a PIN-holding user

- Preconditions: 9000000017 has `profiles.pin_set = true` (checked with read-only SQL).
- Steps: Obtain an OTP-only session (no PIN step). Call `POST /rest/v1/rpc/resident_dashboard` and `GET /rest/v1/society_memberships`.
- Expected: if PIN is a second factor, the OTP-only token should be limited until the PIN is entered.
- Actual: both calls return 200 with full data (flat A Wing-101, society, household counts, membership list). JWT `amr = [{"method":"otp"}]`.
- Status: Fail → SEC-003.
- Evidence: `docs/qa/evidence/secperf/pin-bypass.txt`

SEC-TC-03 PIN storage

- Steps: code review of `apps/web/lib/auth/pinCore.js`, `pinSecret.js`, `app/actions/codeLogin.js`.
- Expected: PIN never stored in plaintext; offline guessing not possible.
- Actual: PIN credential is `pk2.` + base64url(HMAC-SHA256(PIN_PEPPER, "91:")), stored as the GoTrue password (bcrypt). Pepper required (>= 32 chars) outside dev, fails closed. Weak PINs (1234, four identical) refused. BUT legacy `pk1.<phone>.<pin>` is still accepted (`allowLegacy !== false`).
- Status: Fail (legacy path) → SEC-004. Peppered scheme itself: Pass.

SEC-TC-04 PIN attempt throttling

- Steps: code review of `runPinLogin`.
- Expected: lockout per phone and per IP.
- Actual: 5 failures / 15 min per phone → 15 min lock; 30 / 15 min per IP. IP taken from the first `X-Forwarded-For` value (`clientIpFrom`), which a client can forge if the app is not behind a proxy that overwrites it. Not executed live: running 5 wrong PINs would lock a shared test account and GoTrue's `sign_in_sign_ups = 10 / 5 min` is per IP for all testers on 127.0.0.1.
- Status: Fail → SEC-005 (per-phone lock is correct by code review; per-IP key forgeable). Live lockout run not executed (reason above).

SEC-TC-05 OTP throttling configuration

- Steps: read `supabase/config.toml [auth.rate_limit]` and `[auth.sms]`.
- Actual: `sms_sent = 30/h`, `sign_in_sign_ups = 10 / 5 min / IP`, `token_verifications = 30 / 5 min / IP`, SMS `max_frequency = 60s` per phone (send-sms hook `5s`). Edge function per-phone limit via `otp_requests` table.
- Status: Pass (config). Live burst test: Not Tested (would exhaust the shared per-IP bucket for other testers; OTP sending excluded from load by brief).

2. Dev-only backdoors and exposure

SEC-TC-06 Dev routes reachable

- Steps: `curl -I /dev-login?as=9000000009&next=//evil.com`, `curl /dev-preview`, `curl /dashboard` signed out.
- Actual: `/dev-login` 307 → `/dashboard` with a new `sb-127-auth-token` cookie; `/dev-preview` 200; signed-out `/dashboard` 307 → `/dev-login?next=%2Fdashboard`, i.e. every signed-out visitor is auto-signed in as the default persona.
- Status: Fail (expected for dev, but must not ship) → SEC-002.

SEC-TC-07 Network exposure of the dev stack

- Steps: `ss -ltnp`; `curl http://192.168.31.172:3000/dev-login?as=9000000009` (LAN address); `curl http://192.168.31.172:54321/rest/v1/`; TCP connect to 192.168.31.172:54322.
- Actual: next-server listens on `*:3000`; Supabase 54321 and Postgres 54322 on `0.0.0.0`. Over the Wi-Fi address, `/dev-login` returned 307 and a session cookie; 54321 returned 200; 54322 accepted a TCP connection. The laptop is also on ZeroTier (10.0.0.31). `/dev-login?as=9000000030` would give anyone on those networks the platform admin console (not executed for 30; executed for own number 09).
- Status: Fail → SEC-001.

SEC-TC-08 Dev backdoor inventory (code)

- Found: `supabase/config.toml [auth.sms.test_otp]` (30 numbers → 123456) and `[auth.hook.send_sms]` → `public.dev_send_sms` (migration `20260721000033_dev_sms_onscreen.sql`); `components/auth/DevOtpHint.jsx` (used by `VerifyShell.jsx`, login page); `app/dev-login/route.js`; `app/dev-preview/page.jsx`; dev auto-sign-in branch in `app/(protected)/layout.jsx` and `lib/supabase/middleware.js`; `DEV_PIN_PEPPER` constant in `lib/auth/pinCore.js`; `FANOUT_WEBHOOK_SECRET` public dev value in config.toml. Mitigations already present: `devRoutesEnabled()` needs NODE_ENV=development AND ENABLE_DEV_ROUTES=1; `scripts/check-no-dev-otp.mjs` CI check; `supabase/DEPLOY.md`.
- Status: Fail (release blocker) → SEC-002.

3. Session handling

SEC-TC-09 JWT lifetime and refresh

- Actual: access token `exp - iat = 3600 s` (decoded, not printed); refresh token issued; `enable_refresh_token_rotation = true`, `refresh_token_reuse_interval = 10`. Custom access-token hook adds `app_metadata.society_id` and `role`.
- Status: Pass.

SEC-TC-10 Auth cookie attributes

- Actual (dev): `sb-127-auth-token`, `Path=/`, `SameSite=lax`, `Max-Age=34560000` (400 days), no `HttpOnly`, no `Secure` (Secure is set only in production by `cookieOptions.js`). HttpOnly deliberately off (documented) because the browser client reads it.
- Status: Fail (Low) → SEC-007.

4. Redirects and direct URL access

SEC-TC-11 Open redirect via `next=`

- Steps: `/dev-login?as=9000000009&next=<v>` for `//evil.com`, `/%5Cevil.com`, `%2F%2Fevil.com`, `/%09/evil.com`, `https://evil.com`, `/%2F%2Fevil.com`, `/..//evil.com`. Login and verify pages use the same `safeNextPath`.
- Actual: all fall back to `http://localhost:3000/dashboard` except `/..//evil.com` → `http://localhost:3000//evil.com` (absolute, same origin, safe).
- Status: Pass.

SEC-TC-12 Signed-out direct access to protected routes

- Steps: curl signed out: `/dashboard /household /approvals /import /setup /verification/admin /c/test /guard /society-dashboard`.
- Actual: all 307 to the sign-in route (in dev: `/dev-login`).
- Status: Pass.

SEC-TC-13 Middleware static-extension bypass

- Steps: signed out: `/staff/manage/abc.js`, `/residents/owners.json`, `/residents/x.css`, `/c/abc.json`, `/join/invite/abc.js`.
- Actual: middleware lets them through (`STATIC_FILE_RE`), but each page/layout redirects (`NEXT_REDIRECT;replace;/dev-login?next=/dashboard;307`, `/c/abc.json` → `/login`). Grep of bodies found no society names or phone numbers.
- Status: Pass (no leak) with SEC-008 raised as hardening.

5. Web security headers

SEC-TC-14 Headers on `/`

- Actual: `X-Frame-Options: DENY`, `X-Content-Type-Options: nosniff`, `Referrer-Policy: strict-origin-when-cross-origin`, `Permissions-Policy` (camera, mic, geo, payment, usb off), COOP same-origin, CORP same-site, CSP with `default-src 'self'`, `frame-ancestors 'none'`, `object-src 'none'`, `base-uri 'self'`, `form-action 'self'`; `X-Powered-By` absent. Dev CSP adds `'unsafe-eval'`, `ws: wss:`. HSTS absent in dev by design (`next.config.js` adds it in production only; not verifiable without a production build, which the brief forbids).
- Status: Pass (dev). HSTS: Not Tested (needs production build). `'unsafe-inline'` noted in SEC-007.

6. Database: SECURITY DEFINER functions and grants

SEC-TC-15 SECURITY DEFINER functions without `search_path`

- Steps: read-only SQL over `pg_proc` (public schema, `prosecdef`, `proconfig`).
- Actual: 208 SECURITY DEFINER functions in `public`, 43 in `app_private`; 0 in `public` without a pinned `search_path`.
- Status: Pass.

SEC-TC-16 SECURITY DEFINER functions executable by `anon`

- Actual: only `submit_connect_request(...)` and `get_connect_request_status(text, text)` — matches API.md.
- Status: Pass.

SEC-TC-17 SECURITY DEFINER functions with no visible caller check

- Steps: functions executable by `authenticated` whose body has no `auth.uid` / `jwt` /role-helper reference.
- Actual: `family_invite_preview(p_token)` (token is the credential, OK), `guard_list_flats()` (uses `current_guard_society_id()`, raises NOT_GUARD, OK), `society_accepts_joins(p_society_id)` (no check; returns whether the society exists and is not blocked).
- Status: Fail (Low) → SEC-009.

SEC-TC-18 RLS enabled on every public table

- Actual: 0 public tables without RLS.
- Status: Pass.

SEC-TC-19 Anon table grants and anon reads

- Steps: list `role_table_grants` for anon; `GET /rest/v1/<table>?limit=1` as anon for all 35 tables.
- Actual: anon has grants on 33 tables (write grants on bookings, facility_events, flat_actions, moderation_events, notification_preferences, notifications, platform_features, poll_options, poll_votes, polls, post_comments, posts, reports, society_features, society_highlights, society_staff, sos_alerts, visitor_requests). Every anon read returned `[]`; `profiles` and `society_enrollment_requests` return 401 permission denied.
- Status: Pass (no data exposed) with SEC-006 raised as defence in depth.

SEC-TC-20 `profiles` (phones) not readable through PostgREST

- Steps: as member 9000000017, `GET /rest/v1/profiles?select=full_name,phone`.
- Actual: 403 `permission denied for table profiles`.
- Status: Pass.

7. Coverage status and tests still to run

The session ended before these checks ran in this file. Where another tester covered a topic, the evidence is linked. Everything else is **Not Tested** and must run before release.

Topic	Status	Evidence or steps to run
IDOR and cross-society access	**Pass** (API tester)	38 isolation checks in `PARISAR_API_DATABASE_TESTING.md` (area `iso`): a user of society A gets nothing from society B through tables and RPCs. Browser: CORE-TC-032 (another flat's complaint by URL shows "not found"). Found: API-002, where residents read every flat's visitor log in their own society
File upload validation	**Partially tested**	CORE-TC-019 Pass (non-image refused); CORE-TC-020 Fail (corrupt 6 MB "image" accepted, CORE-007). Proof bucket (`parisar-proofs`) not tested: upload .exe renamed .pdf, a 15 MB file, and a path with `../` as a tenant; expect refusal
Stored XSS	Not Tested	Put `<img src=x onerror=alert(1)>` and `"><script>alert(1)</script>` in a complaint description, a notice title, a community post, a profile name, a connect-request message and an Excel name cell. View each as another user. Expect the text shown literally and no script run
Reflected XSS	Not Tested	Open `/login?next=javascript:alert(1)`, `/connect/success?code=<script>`, `/import?x="><svg onload=alert(1)>`. Expect no execution
SQL injection	Not Tested	Send `' or 1=1--`, `%' union select` and `;drop` in RPC text parameters (society code, search fields) and PostgREST filters (`?name=eq.x'or'1'='1`). Expect validation errors, never extra rows or SQL errors
CSRF on server actions	Not Tested	From a page on another origin, POST to the set-language and preference server actions with the victim's cookie. Expect Next.js origin checks to refuse
CORS	Not Tested	`curl -I -H 'Origin: https://evil.example' <api>/rest/v1/` and against the web app. Record `Access-Control-Allow-Origin`; production must not reflect arbitrary origins with credentials
Public rate limits	Not Tested here	Submit the connect form and the status lookup 20 times quickly from one IP. Expect `RATE_LIMITED` after the documented limit. OTP send limits are a GoTrue setting: check `supabase/config.toml` and the production dashboard
Source maps and public env	Not Tested	Production build: confirm no `.map` files are served and only `NEXT_PUBLIC_SUPABASE_URL` and the anon key are exposed
Error message leakage	Not Tested	Trigger server errors (for example CORE-001, `/notices` HTTP 500) and confirm no stack trace or SQL reaches the browser in a production build
Logout invalidation	Not Tested	Log out, then reuse the old access token against the API before it expires. Record whether it still works (Supabase JWTs stay valid until expiry unless sessions are revoked)

Parisar Performance Testing (area: secperf)

Date: 10 November 2026. Environment for measured numbers: the developer laptop (8 CPUs, ~15 GB RAM, other services running), `next dev` (DEV mode, not a production build), Supabase local in Docker.

Important: there is no staging environment. Everything in Part B is a **local dev-mode baseline** at low concurrency (10 to 50 virtual users). It says nothing reliable about production. **Capacity for 100, 500, 1,000, 2,000 or 5,000 concurrent users is NOT demonstrated** by this work. Part A is the plan to demonstrate it on staging.

Scope notes

- **Maintenance billing does not exist.** Confirmed by read-only SQL: no table or function for resident maintenance bills, dues or invoices. `society_billing` / `society_payments` / `admin_set_billing` are Parisar's platform billing of societies, not residents. REPORT.md section 9 also lists maintenance bills and payments as having no backend. The "maintenance" scenario is therefore omitted from the plan; add it when the module exists.
- Visitor requests exist (`guard_create_visit`, `visitor_requests` table). Excel import exists (`import_validate_rows`, `import_confirm_batch`). Notifications exist (`notifications` table, fan-out Edge Function).

Part A. Staging performance test plan

A1. Environment required

Item	Requirement
Web	Production build (`next build && next start`, or the real host, e.g. Vercel) — never `next dev`
Supabase	A dedicated staging project on the same plan/compute size as production (connection pooler/Supavisor enabled)
Data	A seeded `LOAD-` dataset: 20 societies x 250 flats (5,000 flats), ~6,000 memberships, 50k complaints, 100k notifications, 20k visitor requests, 5,000 posts
Accounts	5,000 staging test numbers mapped to a fixed staging OTP (staging-only `test_otp`), with PINs set by a seeding script; 100 authority accounts; 40 guard accounts
Load generators	k6 on 2+ machines outside the staging network (5,000 VUs needs ~2-4 GB RAM per 1,000 VUs); or k6 Cloud
Monitoring	Supabase dashboard (CPU, memory, DB connections, pooler), `pg_stat_statements`, Vercel/host metrics, k6 output to InfluxDB/Prometheus + Grafana
Rate limits	GoTrue per-IP limits (sign-in 10 / 5 min, verify 30 / 5 min) will dominate any login test from few IPs. For the login scenario either raise them on staging for the test window or distribute generators; record which

A2. Scenarios

#	Scenario	Script	Type	Description
S1	Simultaneous login	`login-burst.js`	Write (auth)	N users verify OTP at the same moment (per-vu-iterations, 1 each). PIN step measured separately through the web app
S2	Resident dashboard + lists	`read-mix.js`	Read	`resident_dashboard`, `my_society_features`, complaints/notifications/posts/amenities lists, think time 3-8 s
S3	Authority dashboard + resident access	`admin-dashboard.js`	Read	`society_admin_dashboard`, `manager_list_society_residents`, memberships, visitor requests
S4	Visitor requests + notifications	`visitor-and-notify.js`	Write + read	Guards create visits at a constant arrival rate while residents poll pending visitors and notifications. Add a Realtime subscriber variant (k6 websockets)

#	Scenario	Script	Type	Description
S5	Excel import	`import-validate.js`	Write (admin)	Low concurrency (1, 5, 10 admins), batch sizes 100 / 500 / 1,000 / 5,000 rows; latency vs rows; cancel batches afterwards
S6	Public landing	`landing.js`	Read, anon	`/` and `/connect`
S7	Soak	`read-mix.js` with `HOLD=2h` at 50% of the best passing level	Read	Memory leaks, connection growth
S8	Spike	`read-mix.js` with `RAMP=30s` to 2x the level	Read	Recovery time

Excluded from load on purpose: OTP **sending** (real SMS cost, provider limits), connect-request submission (it is rate limited by design; test the limiter functionally), maintenance billing (does not exist).

A3. Load levels

Run each of S2, S3, S6 (and S4 with residents) at **100, 500, 1,000, 2,000, 5,000** concurrent VUs: 2 min ramp, 10 min hold, 1 min ramp down. S1 at 100, 500, 1,000, 2,000, 5,000 simultaneous logins. A mixed run at each level: 70% S2, 10% S3, 10% S4, 10% S6. Stop raising the level when a threshold fails twice in a row; that level minus one is the demonstrated capacity.

A4. Metrics and pass thresholds

Metric	Source	Pass threshold (proposal)
Latency p50 / p95 / p99	k6 `http_req_duration` per tag	reads p95 < 800 ms, p99 < 2 s; login p95 < 1.5 s; import 1,000 rows p95 < 10 s
Throughput (RPS)	k6 `http_reqs`	report per level
Error rate	k6 `http_req_failed`, checks	< 1% (429 counted separately)
CPU	Supabase DB CPU, web host CPU	< 75% sustained
Memory	DB memory, Next server RSS	no growth over soak
DB connections	`select count(*) from pg_stat_activity`, pooler stats	< 80% of pool max, no "too many connections"
Queue backlog	`notifications` fan-out: pending webhook / `net.http_request_queue` rows; Realtime message lag	backlog drains within 60 s after the spike
Slow queries	`pg_stat_statements` top 20 by total time	none > 500 ms mean

A5. How to run

```
 cd docs/qa/scripts/perf
export SUPABASE_URL=https://<staging>.supabase.co SUPABASE_ANON_KEY=<from secret manager> TEST_OTP=<staging code>
./mint-tokens.sh phones.txt > tokens.json      # never commit tokens.json; delete after the run
k6 run -e TARGET_VUS=500 -e SOCIETY_ID=<uuid> -e TOKENS_FILE=tokens.json read-mix.js
```

Scripts read every secret from the environment; none is stored in the repo. Tokens expire after 1 hour (`jwt_expiry = 3600`), so long runs must re-mint or refresh.

A6. Risks to watch (from code review)

- Every dashboard is a `SECURITY DEFINER` RPC that runs several `count(*)` sub-queries per call; at 5,000 users this is the likely hot spot. Check indexes on `society_id`, `status`, `created_at`.

- RLS policies call helper functions per row (`current_society_id()`); check they are `STABLE` and wrapped as `(select ...)` so Postgres caches them.
- `next dev` numbers are not representative: dev mode compiles on demand and disables caching.

Part B. Local dev-mode baseline (measured 10 Nov 2026)

What this is: a short, read-only smoke baseline on the developer laptop (8 CPUs, 15 GB RAM, VS Code and other containers running). Next.js ran in **development mode** (`next dev`), which compiles on request and is far slower than a production build. Supabase ran locally in Docker. Tool: autocannon 8, 20 seconds per run, no think time. One test user (owner 9000000017, QA Sunrise Heights) for the authenticated calls.

What this is not: evidence of production capacity. **No claim of 100, 500, 1,000, 2,000 or 5,000 concurrent-user capacity is made.** Those levels must be run on staging with Part A.

B1. Results

Target	Connections	Requests in 20 s	Avg RPS	p50 ms	p90 ms	p97.5 ms	p99 ms	Max ms	Errors	Non-2xx
`POST /rest/v1/rpc/resident_dashboard`	10	20,157	1,008	97	206	326	359	450	0	2
same	25	13,589	679	90	242	333	380	614	0	0
same	50	14,465	723	104	282	427	518	1,016	0	0
same (rerun)	10	16,812	841	106	166	205	231	299	0	0
`GET /rest/v1/complaints?limit=20`	10	16,903	845	108	177	223	243	317	0	0
same	25	9,963	498	93	273	369	436	604	0	0
same	50	10,755	538	123	291	414	505	1,047	0	0
`GET /` landing page (Next.js **dev mode**)	10	82	4	2,135	3,107	3,734	4,165	4,165	0	0
same	25	65	3	6,569	8,067	8,766	8,778	8,778	0	0
same	50	59	3	11,709	14,802	15,222	15,374	15,374	0	0

The tool reports p97.5 rather than p95; p95 lies between the p90 and p97.5 columns.

B2. Resources during load

Moment	Postgres CPU	PostgREST CPU	Kong CPU	Postgres memory	Postgres connections	Host
During `resident_dashboard`, 10 connections	98% (about one core)	54%	24%	302 MiB	42	CPU 81% user, 0.7% idle; swap almost full (1.9 of 2 GB)
During landing page, 10 to 50 connections	under 1%	under 1%	under 1%	295 MiB	42	`next-server` 119% CPU, 0.9 GB RSS

B3. What the baseline shows

1. **The database API scales out of this box, not up.** Throughput peaks at about 700 to 1,000 requests per second at 10 connections and does not rise with more connections; latency grows instead (p99 roughly doubles from 10 to 50). Postgres is pinned near one core while the laptop has no idle CPU, so the limit here is the laptop, not the code. A staging run on dedicated hardware is required before any capacity statement.
2. **No errors under read load.** Zero socket errors and 2 non-2xx responses out of about 105,000 API requests (cause not captured; re-check on staging).

3. **Dev-mode page rendering is unusable for load measurement.** 3 to 4 pages per second with multi-second latency is the expected cost of `next dev`. Re-run the landing and dashboard pages against `next build && next start` (or the Vercel preview) on staging.
4. **Database connections stayed at 42** (PostgREST pool plus Supabase services), well inside the default limit. Watch pool saturation at 500+ users on staging.
5. **Not measured locally, by design:** write paths (complaints, visitors), OTP login bursts, notifications fan-out and Excel import. These either send OTPs, create data or need the push worker, which is not running locally (see CORE-034 in the screen tests). They are covered by the staging scripts in `docs/qa/scripts/perf/`.

B4. Readiness verdict for performance

Not Tested at the required scale. The 100 to 5,000 concurrent-user targets have no evidence yet. Run Part A on staging before release.

Appendix: Bug Tracker (24 bugs)

The same data, with filters and dropdowns, is in PARISAR_BUG_TRACKER.xlsx. Field and button checks are in PARISAR_FIELD_AND_BUTTON_VALIDATION.xlsx.

ID	Severity	Priority	Module	Title	Steps	Expected	Actual	Status
SEC-002	Critical	P0	Security / Auth	Dev backdoors present (test_otp 123456, dev_send_sms on-screen OTP, DevOtpHint, /dev-login, /dev-preview, dev PIN pepper fallback) — release blocker	1. POST /auth/v1/otp + /auth/v1/verify token 123456 for +919000000017. 2. GET /dev-login. 3. GET /dashboard signed out	None of these exist in a deployable build	OTP 123456 accepted; /dev-login issues a session; signed-out visitors are redirected to /dev-login (auto sign-in)	Open
API-001	High	P1	Complaints	A member can file a complaint attributed to any other flat in the society	1. Sign in as 9000000007 (owner of A-202, QA-T Lotus Society). 2. POST /rest/v1/rpc/file_complaint with p_reporter_flat_id = id of flat A-101 (the chairman's flat), p_kind=society, p_description='QA-T lift not working'. 3. select reporter_flat_id from complaints.	INVALID_FLAT: the reporter flat must be a flat the caller holds an active membership on.	200 {complaint_id: fc45ddee-...}. complaints row has reporter_id = 9000000007 but reporter_flat_id = A-101. file_complaint only checks that the flat is in the caller's society (flats.society_id = v_society_id), not that the caller lives there. The status trail would show the complaint as coming from A-101.	Open
CORE-001	High	P1	Notices	Notices list returns HTTP 500 on server render though the page body shows the empty state	Sign in as 9000000014; open /notices	HTTP 200	Document response is 500; Next dev overlay shows "1 Issue"; body shows "No notices yet"	Open
CORE-002	High	P1	Polls	Polls list returns HTTP 500 on server render	Sign in as 9000000014; open /polls	HTTP 200	Document response is 500 with dev error overlay	Open
CORE-003	High	P1	Home dashboard	Authority without a flat is redirected from /dashboard to /onboarding ("Your details and flat")	Sign in as 9000000014 (secretary, no flat_id); open /dashboard	Society admin dashboard	Redirected to /onboarding with h1 "Your details and flat"; other admin pages remain reachable	Open
CORE-005	High	P1	Complaints	New complaints do not appear in the board list in realtime	Authority 15 opens /complaints. Owner 18 files a complaint. Wait 12 s.	Card appears without reload (list subscribes to complaints INSERT)	Card appears only after reload. complaints is in the supabase_realtime publication; complaint_responses events do arrive, so the complaints row events appear filtered (likely RLS on complaints vs realtime JWT claims)	Open
CORE-006	High	P1	Complaints	Reporter's status badge does not update live when board responds (core loop)	Owner 18 opens own complaint. Authority 15 clicks 'Will resolve soon'. Wait 12 s.	Badge changes Open -> Will resolve soon	Trail entry appears live but badge stays 'Open'; list also stays 'Open' until reload	Open
SEC-001	High	P1	Security / Environment	Dev server and DB listen on all interfaces with dev auto-login on; LAN users can sign in as any test number incl. platform admin	1. ss -ltnp shows *:3000, 0.0.0.0:54321, 0.0.0.0:54322. 2. From the Wi-Fi address: curl http://192.168.31.172:3000/dev-login?as=9000000009	Dev server bound to 127.0.0.1 only; dev login not reachable from other machines	307 + session cookie returned over the LAN address; Supabase API 200 and Postgres port open on LAN and ZeroTier interfaces	Open

ID	Severity	Priority	Module	Title	Steps	Expected	Actual	Status
API-002	Medium	P1	Visitors	Every resident can read every flat's visitor log, including visitor phone numbers	1. Guard 9000000006 logs a visit for flat A-201 (guard_create_visit, visitor_phone 9876500000). 2. Sign in as 9000000007 (plain member, flat A-202). 3. GET /rest/v1/visitor_requests?select=visitor_name,visitor_phone,flat_id.	0 rows: a resident sees only visits for their own flat; managers may see all.	200 with the A-201 visit, visitor name and phone. RLS policy visitor_requests_secretary_read is USING (society_id = current_society_id()) with no role check, so it admits every member, board member and family member of the society. Committee member 9000000004 also read a visit to A-202 (TC-API-446).	Open
CORE-004	Medium	P2	Feature gating	Switched-off features are only hidden from the sidebar; their pages open by direct URL	QA Sunrise Heights has only visitors, staff_directory, directory, polls switched on (society_features). Sign in as 9000000014; open /bookings, /facilities, /community, /flat-actions	Page blocked or "feature not enabled" message; server/RPC refuses	All four render HTTP 200 with full UI; page.jsx files only check user + society; no migration checks society_features before module RPCs	Open
CORE-007	Medium	P2	Complaints	Replaced or abandoned complaint photos stay in storage; image content not validated	Attach big.jpg (6 MB random bytes), then attach photo.png, submit	Only the kept photo stored; invalid image rejected	6 MB invalid .jpg remains in parisar-attachments (no attachments row). Upload happens on selection, so abandoned forms also leave orphans. No client resize/compression	Open
SEC-003	Medium	P2	Security / Auth	PIN not enforced server-side: OTP-only session of a PIN holder has full API access	1. User 9000000017 has profiles.pin_set=true. 2. Get session via OTP only. 3. POST /rest/v1/rpc/resident_dashboard	Requests without the PIN step are refused (e.g. require amr password / custom claim)	200 with full resident dashboard and membership list	Open
SEC-004	Medium	P1	Security / Auth	Legacy PIN credential pk1.<phone>.<pin> is guessable and still accepted; enables direct GoTrue password-grant brute force bypassing app lockout	Code review: lib/auth/pinCore.js legacyPinSecret + runPinLogin (allowLegacy !== false). Any account whose password was never upgraded can be tried at POST /auth/v1/token?grant_type=password with password pk1.91XXXXXXXXX.NNNN	Legacy secrets removed/rotated; legacy fallback off	Legacy fallback on by default; only GoTrue per-IP sign-in limit (10/5 min) protects those accounts	Open
API-003	Low	P3	SOS	A guard cannot resolve an SOS addressed to guards	1. Member 9000000007 raises SOS with p_audience='watchman'. 2. Guard 9000000006 sees it in security_dashboard.active_sos. 3. Guard calls resolve_sos(p_id).	The guard who responds can mark it handled (or the UI says only the raiser/manager can).	400 NOT_ALLOWED. Only the raiser or a secretary/co_secretary can resolve; the guard dashboard keeps counting it as active until then.	Open
CORE-008	Low	P3	Layout	Nested <main> landmarks (layout main#main-content wraps page <main>)	Open /complaints; inspect DOM	One main landmark	Two <main> elements	Open
CORE-009	Low	P3	Complaints	No unsaved-changes warning when leaving a typed complaint	Type description, click Back	Confirm discard	Leaves immediately, text lost	Open
CORE-010	Low	P3	Complaints	Authority responses show flat as '(—)'	Authority without a flat responds	Role label e.g. 'Secretary' instead of empty flat	'By QA Authority One (—)'	Open

ID	Severity	Priority	Module	Title	Steps	Expected	Actual	Status
CORE-011	Low	P3	Complaints	Not-found card also shows 'Check your connection' error	Tenant 19 opens another member's complaint URL	Single clear message	'Complaint not found...' plus 'Couldn't load this. Check your connection and try again.'	Open
ONB-001	Low	P3	Authentication	/verify opened directly shows "Sent to +91" with no number and an active Verify button	1. Signed out, open http://localhost:3000/verify (no ? phone).	Redirect to /login or show "Enter your number first".	OTP screen with blank number after +91, resend countdown running, Verify button usable.	Open
SEC-005	Low	P3	Security / Auth	PIN per-IP throttle keyed on client-supplied X-Forwarded-For	Code review: codeLogin.js callerIp -> pinCore.clientIpFrom uses first X-Forwarded-For value	IP from trusted proxy only	Forgeable; per-phone lock (5/15 min) still holds	Open
SEC-006	Low	P3	Security / Database	anon role has table privileges (incl. INSERT/UPDATE/DELETE) on 33 public tables	Read-only SQL on information_schema.role_table_grants where grantee='anon'	anon has no table grants (only 2 RPCs)	Grants present; RLS returns 0 rows for every anon read	Open
SEC-007	Low	P3	Security / Session	Auth cookie not HttpOnly, 400-day Max-Age, CSP allows 'unsafe-inline' scripts	Inspect Set-Cookie of /dev-login and CSP header of /	Shorter cookie lifetime; nonce-based CSP so XSS cannot read document.cookie	sb-127-auth-token readable by JS, Max-Age=34560000	Open
SEC-008	Low	P3	Security / Routing	Middleware treats any path ending in .<ext> as public	curl signed out /residents/owners.json, /staff/manage/abc.js	Middleware denies	Middleware passes; page layout still redirects; no data leaked	Open
SEC-009	Low	P3	Security / Database	society_accepts_joins(uuid) callable by any signed-in user, reveals society existence/blocked state	Read-only SQL of function body; no caller check	Caller check or same result for missing and blocked	Returns true/false per society id	Open